1과목 : 시스템 보안

1. 어떤 공격을 방지하기 위한 것인가?

Data Execution Prevention(DEP), NX(No Execute)

① XSS 공격
② 힙 스프레이 공격
③ CSRF 공격
④ SQL 인젝션 공격

<문제 해설>
stack과 heap과 같은 버퍼에 할당된 메모리 공간보다 더 많은 데이터를 저장해 버퍼 공간을 망가뜨리는
buffer overflow와 heap spay 같은 취약점공격 방법이 있다.
이 공격방법들은 메모리 기반에서 특정한 코드를 실행하는데
DEP와 NX는 메모리에서 코드가 실행되지 않도록 방어하는 기술이다.
[해설작성자 : 이직준비중]

윗분이 잘 설명했는데 간단하게 기억하는 방법은
Execute(실행하다) 라는 명령을 금지 시킨것으로 추정해볼 때 명령 자체를 아예 실행을 시키지 못하게 하는 것이다.
XSS: 기본적으로 자바스크립트를 포스팅하는 블로그 같은 곳에 넣어서 필요한 정보를 얻어내는 것이다..근데 만약 명령 자체를 막는다? -> 블로그 포스팅 자체를 하지 말라는 거임
CSRF: 보통 쿠키를 이용해서 다른 사이트로의 접속을 시도하는데 이걸 막아버리면 쿠키 시스템도 사용하지 말라는 거임(시스템에 무리 많이 감)
SQLI: 데이터베이스 조회를 하여 정보들을 탈취하는 방법인데 이걸 막아버리면 데이터베이스 사용하지 말라는 거임

결국 힙 즉 메모리에 영향을 주는 것들을 실행하는 힙 스프레이 공격에 대해서 방어가 되는 것이다.

추가팁: 다른거 세개는 네트워크 관련, 힙 스프레이는 시스템 관련. 만약 네트워크를 no execute 하면 내 웹사이트에 접속하는 사용자들을 막겠다는 뜻
[해설작성자 : 쉽게쉽게 설명하자]

짧게...
XSS 공격: 웹 앱 취약점/ 클라이언트 스크립트 삽입
힙 스프레이 공격: : 메모리 취약점 / 코드 삽입, 실행 흐름 변경
CSRF 공격:인증 정보 이용 / 의도치 않은 요청 전송
SQL 인젝션 공격: 데이터베이스 취약점 /SQL 쿼리 조작, 데이터 유출
[해설작성자 : nico1006]

2. 다음 중 옳지 않은 것은?

① 리눅스 시스템에서는 계정 목록을 /etc/passwd 파일에 저장하고 있다.
② 일반 사용자의 사용자 번호(UID, User ID)는 0번으로 부여받게 된다.
③ 디렉토리의 권한은 특수권한, 파일 소유자 권한, 그룹 권한, 일반(Others) 권한으로 구분된다.
④ 접근 권한이 rwxr-xr-x인 경우 고유한 숫자로 표기하면 755가 된다.

<문제 해설>
UID 0 : 관리자
UID 1~100 : 시스템유저
UID 500~65534 : 일반유저
[해설작성자 : 이직준비중]

UID 0: 보통 시스템 관리자 또는 슈퍼유저(root)에게 할당됩니다..슈퍼유저는 시스템 전반적인 관리와 권한을 가지며, 모든 파일 및 리소스에 대한 접근 권한을 갖습니다.
UID 1~99: 시스템 프로세스 및 서비스를 위해 예약된 UID 범위입니다..보통 이 범위는 시스템 유저에게 할당됩니다.
UID 100~65534: 일반 사용자에게 할당되는 UID 범위입니다.. 대부분의 리눅스 시스템에서는 이 범위를 사용하여 일반 사용자 계정을 할당합니다.
UID 65535: 예약된 UID로, 보통 "nobody"라는 이름의 특수 사용자를 나타냅니다..이 사용자는 시스템에서 특정 작업에 의해 사용되는 경우가 있습니다.
[해설작성자 : SHYO]

3. 적절하게 고른 것은?

가. 시스템의 환경 설정 및 주요 설정 파일
나. 프로그램 실행시 생성되는 임시 파일
다. 프린터나 터미널 같은 물리적인 장치를 다루기 위한 특수 파일

① 가 /usr 나/temp 다/dev
② 가 /usr 나/tmp 다/var
③ 가 /etc 나/temp 다/var
④ 가 /etc 나/tmp 다/dev

<문제 해설>
/etc - 시스템 환경설정 파일
/tmp - 임시 파일 폴더
/dev - 장치 드라이버, 터미널, 프린터 등 주변 장치 등을 나타내는 파일
[해설작성자 : comcbt.com 이용자]

/var = variation -> 가변적인 데이터 파일들이 저장됨. 보통 로그 데이터, 임시파일, spool directory 파일 같이 정말 빠른 시일내로 계속적으로 업데이트나 바뀔 필요가 있는 것들이 저장된다고 생각하
[해설작성자 : 한큐에 가자]

4. 인적자원 관리자가 특정 부서 사용자들에게 같은 직무를 수행할 수 있는 접근 권한을 할당하고 있다. 이것은 다음 중 어느 것의 예인가?

① 역할기반 접근 통제
② 규칙기반 접근 통제

③ 중앙집중식 접근 통제
④ 강제적 접근 통제

<문제 해설>
역할 기반 접근통제
권한이 있는 사용자들에게 시스템 접근을 통제하는 방법(DAC와 MAC의 단점을 보완한 방식)

규칙기반 접근통제
특정 시스템에 접근 하고자 하는 모든 사용자에게 부과된 규칙으로 보안설정

중앙집중식 접근 통제
AAA 기능을 하나의 시스템에서 수행하는 방식이다.
※ AAA
> Authentication: 인증 (ID/PW, 생체 인식, PKI 등)
> Authorization: 인가 (MAC, DAC, RBAC 등)
> Accountability: 책임추적 또는 과금 (로깅, Audit 등)

강제적 접근 통제
사용자가 자원에 접근 할때 사용자의 비밀 취급 레이블과 각 개체에 부여된 민감도에 따라 접근을 통제
[해설작성자 : 맞나?아닌가?]

역할기반 접근통제(RBAC)
각각의 사용자에게 접근 권한을 할당하는 것이 아니고, 역할에 접근 권한을 할당, 예를들면 네이버 카페의 등급이다..사원/대리/과장/차장/부장/이사/사장 등급이 있다고 하면, 사원등급 사용자들은 과장 등급 사용자들이 사용하는 페이지를 볼 수 없다..나의 역할이 과장이 아니기 때문이다..물론 반대의 경우도 똑같다..내가 어떤 역할 그룹에 있냐에 따라 사용할 수 있는 범위가 다르다.

규칙기반 접근통제:
객체에 포함된 허용등급과 접근 정보에 대하여 주체가 갖는 접근 허가 권한에 근거. 객체의 소유자가 그 권한을 변경 못함. 중앙화 되어있음. 쉽게 이해하자면, 1급기밀, 2급기밀 같은거. 1급기밀은 대통령과 그 직속보좌 팀 아니면 못본다고 한다는 규칙이 있는 것이다..내가 "대통령이어서" 본다 라는 개념보다는, "1급 기밀이어서" 대통령 밖에 못본다 이런 느낌?

중앙집중식:
위의 설명과 같음. 중앙에서 몽땅 다 관리함

강제적 접근 통제(MAC):
규칙기반이랑 똑같은 말임
[해설작성자 : 쉽게쉽게 설명하자]

5. 윈도우 레지스트리 하이브 파일이 아닌 것은?

① HKEY-CLASSES-ROOT
② HKEY LOCAL-MACHINE
③ HKEY-CURRENT-SAM
④ HKEY-CURRENT-USER

<문제 해설>
*레지스트리 편집기를 켰을때 나오는 기본키(루트키)
HKEY_CLASSES_ROOT : 파일확장자, 프로그램 연결정보
HKEY_CURRENT_USER : 윈도우 설정과 프로그램정보
HKEY_LOCAL_MACHINE : 설치된 하드웨어, 설치드라이버 정보
HKEY_USER : 사용자 정보
HKEY_CURRENT_CONFIG : 디스플레이, 프린트 정보

*하이브 파일이란?
레지스트리 정보를 가지고 있는 물리적 파일
서브키로부터 그 아래의 모든 서브키를 포함하는 트리 구조를 가짐
[해설작성자 : 정미사랑 나라사랑]

CURRENT_USER: 현자 시스템에 로그인 된 사용자의 프로필 정보, 현재 사용하는 계정이 admin이라면, 얘는 무슨 배경화면인지, 어떤 응용 프로그램을 사용하는지 등등을 알려줌
USER:시스템의 모든 사용자와 그룹에 대한 프로필. admin, user, guest, A, B 등등 사용자들의 파일을 보관
[해설작성자 : 쉽게쉽게 설명하자]

6. 윈도우 NTFS에서 모든 파일들과 디렉터리에 대한 정보를 포함하고 있는 것은?

① MFT(Master File Table)
② FAT(File Allocation Table)
③ $Attr Def
④ $LogFile

<문제 해설>
MFT?
볼륨에 존재하는 모든 파일과 디렉터리에 대한 정보를 가진 테이블
NTFS의 가장 중요한 구조체

FAT?
MS-DOS 용으로 개발 된 파일 시스템
NTFS 출시 이전 Windows에서 기본 파일 시스템으로 사용되었음
디스크의 공간 부트 섹터, 파일 할당 테이블 영역, 루트 디렉토리 영역 및 데이터 영역의 네 부분으로 되어있음
[해설작성자 : 정미]

7. 리눅스/유닉스 시스템에서 로그를 확인하는 명령어나 로그파일과 가장 거리가 먼 것은?

① wtmp ② history
③ pacct ④ find

<문제 해설>
로그 확인 명령어
utmp(현재사용자), wtmp(로그인/아웃 정보,btmp(로그인실패), last(마지막 성공한 로그정보)

history
이전에 사용한 명령어를 순서대로 확인가능함

acct/pacct
시스템에 로그인한 모든 사용자가 로그아웃할 때까지 입력한 명령어와
터미널의 종류, 프로세스 시작 시간 등을 저장한 로그이다.

xferlog 로그 파일
리눅스 시스템의 FTP 로그 파일로서 ftpd의 서비스 내역을 기록하는 파일

find
파일 검색(찾기)관련 명령어
[해설작성자 : 정미사랑 나라사랑 맞나?]

쉽게 답 찾는법:
wtmp = who? temporary -> 누가 로그인 로그아웃했냐? 누구야!
history = 말 그대로 역사임, 어떤 명령어를 입력한 역사가 있냐는 거임
acct/pacct = account/process account -> 계정/사용중 계정, 곧 얘네가 이 계정갖고 뭘했는지 알아내는거
find = 찾다, 파일을 찾아야지 뭐
[해설작성자 : 쉽게쉽게 설명하자]

8. 다음 지문이 설명하는 데이터베이스 보안 유형은 무엇인가?

> 전체 데이터베이스 중 자신이 허가 받은 사용자 관점만 볼 수 있도록 한정한 것

① Access Control ② Encryption
③ Views ④ Authorization Rules

<문제 해설>
DB 보안
- DB를 무단으로 사용하거나 변경을 금지하고, 악의적인 위험으로부터 보호하기 위한 대안

1. 접근제어
2. 권한부여
- 로그인절차나 접근 통제를 거쳐 들어온 사용자에게 허가받은 데이터만 접근이 가능하도록
2-1 가상테이블(View) : 허가받은 사용자 관점에서만 볼 수 있도록 가상 테이블을 만들어줌
2-2 암호화(Encryption) : 파일에 접근했더라도 알아보지못하게 암호화 하는것
[해설작성자 : 정미사랑 나라사랑]

Access Control: 접근 제어, 특정 파일에 누가 접근하고 접근하지 말아야 할 것인지에 대한 통제방식.
Encryption: 암호화
Views: 데이터베이스를 볼 수 있는 관점
Authorization Rules: 권한 부여 규칙, 로그인 하면 이 사용자에게 어떤 권한을 부여할지 정하는 방법
[해설작성자 : 누가 더 좋은 설명좀 해줘...]

9. 패스워드와 함께 일방향 해시함수에 입력되는 12비트 난수값은?

① 세션키 ② 메시지
③ 솔트(salt) ④ 멜로리

<문제 해설>
솔트(Salt)
솔트란 해시함수를 돌리기 전에 원문에 임의의 문자열을 덧붙이는 것
원문에 임의의 문자열을 붙인다는 의미의 소금친다(salting) 는 것

어지간한 해시 함수는 알고리즘을 공개하기 때문에 이를 악용하여 사전 공격의 일종인
레인보우 테이블 공격을 할 수 있다..
ex) 암호화 할때 "암호"라는 암호화값과 "암호123"은 다이제스트 값이 다르다
[해설작성자 : 정미]

세션키 (Session Key): 통신 보안, 임시 생성, 대칭 암호화
메시지 (Message): 데이터 전송, 정보 포함, 통신
솔트 (Salt): 비밀번호 보안, 암호화, 무작위 생성
멜로리 (Melory): 암호화, 보안 강화, 데이터 보호
[해설작성자 : nico1006]

10. 아이노드(i-node)가 가지고 있지 않은 정보는?

① 파일의 이름 ② 파일의 링크 수
③ 파일 수정시각 ④ 파일 유형

<문제 해설>
아이노드가 가지고 있는 정보
-파일 소유자의 사용자 ID
-파일 소유자의 그룹 ID
-파일 크기
-파일이 생성된 시간
-최근 파일이 사용된 시간
-최근 파일이 변경된 시간
-파일이 링크된 수
-접근모드
-데이터 블록 주소
[해설작성자 : 정미사랑 나라사랑]

아이노드: 파일에 대한 정보(메타데이터)를 가진 데이터.
파일의 내용에는 관심은 없고, 파일 자체가 어떤 것이냐를 알려줌.
예) 예산결과보고서.docx 라는 워드파일이 있다면, 예산이 얼마냐, 제목이 뭐냐가 궁금한게 아닌, 이 파일은 누가 작성했고, 누가 볼 수 있고, 크기는 얼마나 되고, 언제 만들어졌고 이런거
[해설작성자 : 쉽게쉽게 설명하자]

11. 다음 악성코드에 대한 설명 중 옳지 않은 것은?

① 루트킷(Rootkit)은 단일 컴퓨터 또는 일련의 컴퓨터 네트워크에 대해 관리자 레벨의 접근을 가능하도록 하는 도

구의 집합이다.
② 웜(Worm)은 네트워크 등의 연결을 통하여 자신의 복제품을 전파한다.
③ 트로이목마(Trojan Horse)는 정상적인 프로그램으로 가장한 악성 프로그램으로 보통 복제 과정을 통해 스스로 전파된다.
④ 트랩도어(Trapdoor)는 정상적인 인증 과정을 거치지 않고 프로그램에 접근하는 일종의 통로이다.

<문제 해설>
트로이목마(Trojan Horse)는 정상적인 프로그램으로 가장한 악성 프로그램까지는 맞는 말입니다.
다만 트로이 목마가 복제 과정을 통해 스스로 전파되지는 않습니다.
[해설작성자 : comcbt.com 이용자]

루트킷: 루트 권한(관리자 권한)을 얻어온다 생각하자
웜: 자기 복제가 가능하다는 점에서 바이러스랑 비슷, 바이러스와 다른 점은 바이러스는 실행해야 전여되지만, 웜은 실행하지 않아도 전염
트로이목마: 정상인척 침투해서 정보를 빼오거나 악성 행위를 실행. 복사는 안됨
트랩도어: 일방향 함수의 역을 구해내는 것. 고로 정상적으로 일방향 함수를 거치지 않고, 역으로 계산해내서 인증을 이뤄냄
[해설작성자 : 누가 더 좋은 설명좀 해줘...]

12. 디스크 공간 할당의 논리적 단위는?

① Volume ② Page
③ Cluster ④ Stream

<문제 해설>
Volume - 디스크에서 하나의 논리적인 파티션.
Cluster - Sector들의 모음, 파일 시스템은 파일을 저장하기 위해 할당할 수 있는 가장 작은 논리적 디스크 공간
Page - 물리디스크를 논리적으로 분리할때 필요한 단위
[해설작성자 : 정미사랑 나라사랑]

볼륨: c, d같은 드라이브라고 생가갈면 된다..이는 디스크 공간 할당과 관련 있는 것이 아닌 디스크 자체를 볼륨이라고 부른다.. 물론 볼륨은 드라이브의 논리적 표현이다.
페이지: 메모리에서 사용하지 않는 부분을 하드디스크에 넣기 위해서 사용하는 단위
클러스터: 섹터들의 모음, 섹터란 도넛+피자 모양으로 작은 디스크의 한조각 같은 느낌? (뭐라고 설명해야 되지?)
[해설작성자 : 한큐에 가자]

Volume: 저장공간 / 물리적 디스크 / 파티션
Page: 메모리 관리 / 가상 메모리 / 페이지 교체
Cluster: 파일 시스템 / 데이터 저장 단위/ 디스크 공간 관리
Stream: 데이터 전송 / 파일 입출력 / 네트워크 통신
[해설작성자 : comcbt.com 이용자]

13. 다음 중 파일 시스템의 무결성 보장을 위해 점검해야 할 사항으로 옳지 않은 것은?

① 파일의 소유자, 소유그룹 등의 변경 여부 점검
② 파일의 크기 변경 점검
③ 최근에 파일에 접근한 시간 점검
④ 파일의 symbolic link의 수 점검

<문제 해설>
무결성이랑 링크는 관련이 없다고 하신 분이 있는데, 관련 있습니다.
문제에서 뜻하는 '파일 시스템의 무결성 보장을 위해 점검해야 할 사항'이란 i-node의 변경여부를 통해 알 수 있습니다.
'i-node'는 파일에 대한 정보들과 디스크 블록의 주소를 저장하는 필드들로 구성되어 있는 '자료구조'로, 실제 파일 관련 내용을 갖고 있지는 않습니다..
i-node가 가지고있는 주요 정보로는 [i-node번호, 파일유형, 파일크기, 파일 링크 수, 마지막으로 수정,접근,변경된 시간] 입니다..여기서 '파일 링크 수'란 '해당 아이노드에 대한 참조 수' 즉, '하드링크의 참조 수'를 가르킵니다.
하드링크(hard link)는 원본 파일과 동일한 i-node를 직접적으로 가리키므로 대상파일과 동일한 i-node 번호와 허가권을 가집니다..원본파일이 삭제되어도 데이터만 있다면 원본파일에 접근이 가능하구요, 때문에 하드 링크 수를 점검하여 무결성 여부를 판단 할 수가 있죠.
4번에서 지시하는 '심볼릭 링크(symbolic link)=소프트링크' 는 생성하면 대상 파일과는 또 다른 i-node를 생성하게 됩니다..파일허가권도 다르고, 원본파일이 사라지면 해당 데이터에 접근할 수 없습니다..즉 대상 파일과 i-node값이 달라졌는데 대상 파일 시스템에 대한 무결성 점검을 어떻게 하겠습니까.
그냥 짧게 말해서 파일의 하드링크 수 점검이 아닌 심볼릭 링크 수 점검 이라 나와있어서 4번이 틀린거에요.
[해설작성자 : 호감고닉미다]

윗분이 잘 설명해주셨음, 조금 더 쉽게 외우는 방법은 심볼릭 링크를 윈도우로 표현하면 바로가기이다.
바탕화면에 깔린 바로가기 지운다고 그 프로그램 자체가 안지워진다는 것을 다 알거라 생각함.
바로가기가 바탕화면에 있고, 직박구리에 있고, 까치파일에 있고, D 드라이브에 있고... 이런 바로가기들이 많다고 해서 시스템이 안전한 것도 아니고, 바로가기가 없다고 해서 시스템이 불안한 것도 아님
[해설작성자 : 누가 더 좋은 설명좀 해줘...]

14. 다음 파일시스템(FAT, NTFS)에 대한 설명 중 옳지 않은 것은?

① FAT 뒤의 숫자는 표현 가능한 최대 클러스터 개수와 관련되어 있다.
② NTFS 파일시스템은 대용량 볼륨, 보안 및 암호화를 지원한다.
③ NTFS 파일시스템은 타 운영체제 호환이 용이하다.
④ 저용량 볼륨에서는 FAT가 NTFS보다 속도가 빠르다.

<문제 해설>
NTFS는 "윈도우NT"의 파일 시스템(FS)을 말한다
윈도우2000이나 윈도우XP, 윈도우 비스타도 윈도우NT계열의 운영체제이므로 NTFS를 사용할 수 있음

NTFS 이전에는 FAT 또는 FAT32라는 파일시스템이 사용되었음

*대부분의 파일 시스템은 파일 이름등을 따로 기록하고 있음
이를 FAT는 테이블 형태로 저장하고 NTFS는 B-트리로 저장함, NTFS의 탐색 속도가 훨씬 빠르다.

NTFS 파일시스템은 타 운영체제 호환이 안되는건 아니지만 용이하다고 볼 수는 없음
[해설작성자 : 정미사랑 나라사랑]

대체로 NTFS = 윈도우 ext = 리눅스 라고 생각하면 된다.
FAT는 둘다 되는거고....
[해설작성자 : 한큐에 가자]

15. 다음 중 SECaaS에 대한 설명으로 적합하지 않은 것은?

① 클라우드 컴퓨팅 환경 하에서 인터넷을 통하여 보안서비스를 제공하는 것을 두고 SECaaS(Security as a Service)라고 한다.
② SECaaS는 Standalone으로 클라우드 기반 보안서비스를 제공하는 형태와 클라우드 서비스 제공업체가 자사의 고객에게 보안기능을 제공하는 형태로 나뉠 수 있다
③ SECaaS는 보안서비스를 ASP 형태로 공급한다는 측면에서 넓은 의미의 PaaS(Platform as a Service) 로 볼 수 있다.
④ SECaaS는 인증, 안티바이러스, 침입탐지, 모의침투, 보안이벤트 관리 등의 다양한 보안 기능을 제공할 수 있다.

<문제 해설>
SECaaS (서비스로서의 보안(Security as a Service))
클라우드 기반 보안서비스라고 생각하면 됨
- 클라우드처럼 사용한 만큼만 비용을 지불하면됨,
- 필요할 때 적용 가능
- 비용 절감
- 전문 인력 없이 보안 수준 향상 가능
[해설작성자 : 정미사랑 나라사랑]

Iaas Paas Saas의 차이
Iaas: 운영체제 설치가 안되어있음. 내가 마음껏 운영체제 설치할 수 있음. ex)VMWare Exsi 같은거
Paas: 운영체제까지는 설치가 되어있음. 근데 무엇을 설치하고, 어떤 어플을 쓸지, 어떤 데이터를 넣을지는 스스로 결정, 쉽게 말하자면 내가 개발만 하고 나머지는 클라우드로. 데이터베이스도 이에 해당
SaaS: 모든게 다 세팅되어있고 클리만 하면 됨. 넷플릭스 같은거. (넷플을 저장하는 저장소는 우리 핸드폰에 있는게 아님)
[해설작성자 : 누가 더 좋은 설명좀 해줘...]

16. SAM에 대한 설명으로 옳지 않은 것은?

① 사용자 패스워드는 해시된 상태로 저장된다.
② SID를 사용하여 각 자원에 대한 접근권한을 명시한다.
③ SAM 파일은 사용자, 그룹 계정 및 암호화된 패스워드 정보를 저장하고 있는 데이터베이스이다.
④ 사용자 로그인 정보와 SAM 파일에 저장된 사용자 패스워드 정보를 비교해 인증 여부가 결정된다.

<문제 해설>
정리정리
SAM = 보안 계정 관리자임
- 윈도우 사용자 비밀번호를 저장하는 DB관리파일
- 사용자의 로그인 입력 정보와 SAM의 DB 정보를 비교하여 인증 여부를 결정
- 해시된 비밀번호는 한번 더 암호화 해서 저장

LSA = (Local Security Authority)보안 서브 시스템이라고도 불림
- 계정명과 SID(Security ID)를 매칭하여 검증, 시스템 자원 및 파일 등에 대한 접근 권한을 검사
- 모든 계정의 로그인에 대한 검증을 하고, 시스템 자원 및 파일 등에 대한 접근 권한을 검사

SRM (Security Reference Monitor)
- SAM이 계정과 패스워드를 확인하여 SRM에게 알려주면, 인증된 사용자에게 SID 부여
- SID : 500=Administrator, 501=Guest, 일반유저=1000이상
[해설작성자 : 정미사랑 나라사랑]

SAM 빼고 다 SID를 사용하고, SAM은 해시 비밀번호를 사용한다는 것을 인지하자
[해설작성자 : 쉽게쉽게 설명하자]

아주 짧게 정리함.
SAM (Security Account Manager): 사용자 계정 관리 / 로컬 인증 정보 저장 / 비밀번호 해시
LSA (Local Security Authority): 로컬 시스템 보안 / 권한 할당 / 인증 및 권한 검사
SRM (Security Reference Monitor): 시스템 리소스 접근 제어 / 보안 정책 적용/ 권한 확인 및 모니터링
[해설작성자 : nico1006]

17. 로그분석에 사용되며 문자열을 처리하는 Unix 명령어와 가장 거리가 먼 것은?

① awk ② wc
③ grep ④ nohup

<문제 해설>
nohup 의미
“no hangups”(전화끊지 마)로, 쉘 스크립트파일을 데몬 형태로 실행시키는 명령어
나머지 awk, wc, grep는 문자열 처리관련 명령어
[해설작성자 : 정미사랑 나라사랑]

awk: Aho + Weinberger + Kernighan -> 입력으로 지정된 파일로부터 데이터를 분류하고, 분류된 데이터를 바탕으로 패턴 매칭 여부 검사, 데이터 조작 및 연산등을 수행하고 그 '결과'값을 출력해주는 기능, 즉 문자를 입력받아 어떠한 처리과정을 거

친뒤 결과를 반환
wc: word count -> 특정 파일에 존재하는 바이트 수, 단어 수, 행의 수를 카운트하여 화면에 출력.
grep: 특정 파일에서 지정한 문자열이나 정규표현식을 포함한 행을 출력해주는 명령어. ex) grep 'wow' good.txt -> good.txt 파일에서 wow 문자열 찾기
[해설작성자 : 합격만 시켜주세요..]

18. 다음 지문에서 설명하고 있는 침입탐지 기술이 무엇인지 고르시오.

- 공격자의 동작에 관한 정보를 수집한다. - 공격자가 시스템에 충분히 오랜 시간 동안 머무르기를 유도함으로써 관리자가 반응할 수 있도록 한다.

① IDS(Instrusion Detection System)
② IPS(Instrusion Prevention System)
③ UTM(Unified Threat Management)
④ Honeypot

<문제 해설>
Honeypot (꿀단지)
탐지하기 위해 의도적으로 설치해 둔 시스템
[해설작성자 : 정미사랑 나라사랑]

IDS(침입 탐지 시스템): 지나간 패킷을 복사하여 검사함. 네트워크 부하가 덜하지만 공격 패킷을 실시간으로 차단하지 못하고 관리자에게 알려주는 역할만 함.

IPS(침입 방지 시스템): 실시간으로 탐지하고 공격 패킷까지 차단 가능하지만, 네트워크에 부하가 많이 갈 수 있으며, 정상적인 패킷을 오탐하여 막아버리는 불상사가 발생할 수 있음

UTM(통합 위협 관리): 하나의 장비에서 여러 보안 기능을 통합적으로 제공함. 성능도 좋고 가격도 저렴함. 방화벽, VPN, IDS/IPS, 안티 바이러스, 안티스팸 등등등 엄청나게 많은 기능이 있음.

Honeypot: 파리지옥? 같은 느낌이라 생각하면 편하다..오랫동안 머물게 하면서 공격자에게 이런저런 습관이 있구나 라는 것을 파악이 가능함.
[해설작성자 : 쉽게쉽게 설명하자]

19. 다음 중 Unix 시스템에서 secure.txt 파일의 소유자에게는 읽기와 실행권한을 부여하고 다른 사용자에게는 읽기 권한을 제거하라는 권한 변경 명령으로 알맞은 것은?

① #chmod 306 secure.txt
② #chmod 504 secure.txt
③ #chmod otrx, a-r secure.txt
④ #chmod u=rx, o-r secure.txt

<문제 해설>
문자를 이용하여 권한추가
chmod a-x [Element] :모든 사용자 및 그룹에게 실행 권한을 제거
chmod u+x,go-w [Element] : 소유자에게 실행권한 부여, 그룹 및 기타 사용자에게 쓰기 권한를 제거
chmod u=rwxm go-wx [Element] : 소유자에게는 읽기,쓰기,실행 권한을 부여, 그룹과 기타 사용자에게는 쓰기와 실행 권한을 제거

숫자를 이용하여 권한추가
chmod 644 [Element] : 소유자는 읽기 쓰기, 그룹과 기타사용자는 읽기 권한 부여
chmod 755 [Element] : 소유자에게는 읽기,쓰기,실행 권한을 부여, 그룹과 기타사용자는 읽기, 실행 권한 부여
[해설작성자 : 정미사랑 나라사랑]

20. 리눅스에서 관리하는 주요 로그파일에 대한 설명으로 옳지 않은 것은?

① /var/log/cron : 시스템의 정기적인 작업에 대한 로그
② /var/log/messages : 커널에서 보내주는 실시간 메시지
③ /var/log/secure : 시스템의 접속에 관한 로그로 언제/누가/어디의 정보를 포함
④ /var/log/xferlog : 메일 송수신에 관한 로그

<문제 해설>
xferlog : FTP 등을 통해 파일 전송된 기록이 저장된 로그파일
[해설작성자 : 이직준비중]

2과목 : 네트워크 보안

21. 다음은 PORT 스캔 공격에 관한 설명이다. 설명 중 맞는 것을 모두 고른 것은?(오류 신고가 접수된 문제입니다. 반드시 정답과 해설을 확인하시기 바랍니다.)

가. PORT 스캔은 공격대상 시스템의 포트가 열려 있는지 확인하는 일종의 공격이다. 나. Stealth 스캔의 대표적인 경우로 TCP Half-Open 스캔이 있다. 다. Null 스캔은 포트가 열려 있을 경우에는 응답이 없고, 닫혀있을 경우에만 RST/ACK 패킷이 되돌아 온다. 라. UDP Open 스캔은 포트가 열려 있을 경우에는 아무런 응답이 없고, 포트가 닫혀있을 경우에는 ICMP Unreachable 패킷을 받게 된다.

① 가, 나
② 가, 나, 다.
③ 가, 나, 라
④ 가, 나, 다, 라

<문제 해설>
다..포트가 열려있으면 응답이 없고, 포트가 닫아 있으면 응답 RST를 보내준다고 합니다.
[해설작성자 : 곤약]

아래와 같은 오류 신고가 있었습니다.
여러분들의 많은 의견 부탁 드립니다.
추후 여러분들의 의견을 반영하여 정답을 수정하도록 하겠습니다.

참고로 정답 변경은 오류 신고 5회 이상일 경우 수정합니다.

[오류 신고 내용]
NULL스캔의 경우에도 열려있을경우 응답이 없으며, 닫혀잇을경우 RST/ACK패킷이 되돌아옵니다..
그러므로 정답은 모두 포함하는 4번이 맞습니다.
[해설작성자 : comcbt.com 이용자]

[추가 오류 신고]
TCP NULL 스캐닝 : 닫혀있을 경우 RST/ACK 패킷이 맞습니다..
답 4번
[해설작성자 : comcbt.com 삼용자]

[추가 오류 신고]
4번이 정답인것 같아요

[관리자 입니다.
다른 문제집 확인 가능한분 계시면 확인 부탁 드립니다.
신고시 출판사명까지 기제 부탁 드립니다.]

[추가 오류 신고]
알기사 정보보안기사 필기 2권 p.443:
Null 스캔을 사용할 시 포트가 열려있으면 응답이 없고, 포트가 닫혀 있으면 RST 패킷을 반환한다..RST는 맞는데 ACK에 대한 언급은 없었습니다.
추가로 Xmas 스캔을 사용할 경우 ACK 부터 시작해서 RST, FIN 등등 많은 패킷들을 설정해서 보낸다고 합니다.

개인적인 결론: RST패킷을 반환해준다고는 했지만, RST/ACK 패킷을 반환해준다고는 책에서 이야기하지 않았습니다..그런 의미에서라면 3번은 틀린것이 되지만, RST, ACK를 같이 보내지 않을까 싶습니다..책에서는 Xmas와 거의 비슷한 스캔 방식이라고 했으니까요. Xmas는 전부 반환
[해설작성자 : comcbt.com 사용자]

22. 다음의 포트 스캔 중 플래그 (SYN, RST, ACK, AN, PS URG)을 모두 off하여 스캔하는 것은?

① TCP SYN 스캔 ② Fin 스캔
③ Null 스캔 ④ Xmas 스캔

<문제 해설>
NULL 스캔 - 플래그 값 (SYN, RST, ACK, AN, PS URG)을 설정하지 않고 보낸 패킷
TCP SYN 스캔
- port open : SYN을 보내고 대상으로부터 SYN/ACK 패킷을 받으면, 즉시 RST 패킷을 보내 연결을 끊음으로써 로그를 남기지 않음 (스텔스 스캔)
- port off : SYN을 보내면 대상으로부터 RST/ACK 패킷을 받음.
TCP FIN 스캔 : TCP 헤더 내에 FIN 플래그를 설정하여 전송
Xmas 스캔 : (크리스마스 의미 맞음)여러가지 플래그를 한번에 전송(선물)
[해설작성자 : 정미사랑 나라사랑]

23. 오용탐지 방법으로 적당하지 않은 것은?

① 시그니처 분석
② 페트리넷(Petri-net)
③ 상태전이 분석
④ 데이터마이닝

<문제 해설>
규칙-기반 침입탐지(오용 침입탐지)
- 전문가 시스템
- 신경망
- 시그니처
- 패트리넷
- 상태전이 분석
- 유전 알고리즘
- 지식기반
행위기반 침입탐지(이상탐지)
- 전문가 시스템
- 신경망
- 통계적 방법
- 컴퓨터 면역학
- 데이터 마이닝
- HMM(Hidden Markov Model)
- 기계학습
[해설작성자 : 정미사랑 나라사랑]

24. 공격 대상이 방문할 가능성이 있는 합법적인 웹 사이트를 미리 감염시킨 뒤, 잠복하고 있다가 공격 대상이 방문하면 대상의 컴퓨터에 악성코드를 설치하는 공격 방법은?

① 악성 봇(Malicious Bot) 공격
② 워터링 홀(Watering Hole) 공격
③ 스피어 피싱(Spear Phishing) 공격
④ 피싱(Phishing) 공격

<문제 해설>
사자가 먹이를 습격하기 위해 물 웅덩이(Watering Hole) 근처에서 매복하고 있는 형상을 빗댄 용어
웹 사이트를 감염시키고, 피해 대상이 그 웹사이트를 방문할 때까지 기다리는 공격 방법
[해설작성자 : 정미사랑 나라사랑]

악성 봇: 악의적인 동작을 하는 기기
워터링 홀: 웹 사이트를 감염시키고 잠복함(구멍 판다고 생각하자)
스피어 피싱: 특정 대상을 목표로 전자우편, 메신저등등을 사용해 메시지를 가장하여 개인정보를 부정하게 얻어내는 행위
피싱: 불특정 다수를 목표로 전자우편, 메신저 등등을 사용해 메시지를 가장하여 개인정보를 부정하게 얻어내는 행
[해설작성자 : 누가 더 좋은 설명좀 해줘...]

25. 다음 중 패킷의 출발지와 목적지 모두를 반영하여 주소 변환을 수행하는 NAT(Network Address Translation)는?

① 동적 NAT ② 정적 NAT
③ 바이패스 NAT ④ 폴리시 NAT

<문제 해설>
NAT 동작방식 분류
동적 : 내부에서 외부의 트래픽만 허용
정적 : 사설주소와 공인주소를 1:1로 변환, 외부에서 내부로의 트래픽 허용
폴리시 : - ACL을 사용하여 출발지와 목적지에 따라 변환을 수행
바이패스 : NAT에 해당하지않으면 그냥 라우팅
[해설작성자 : 정미사랑 나라사랑]

동적 NAT: 내부 네트워크에서 사용되는 주소를 공용 IP 주소로 변환. 포트는 랜덤이며, 일반적으로 PAT라고도 한다.
정적 NAT: 고정된 IP 주소를 가진 장비만 인터넷 접속이 가능. 1:1 대응 관계를 가지는 공용 IP 주소와 내부 IP 주소를 매핑
바이패스 NAT: 내부 IP 주소를 그대로 인터넷에 노출시킴. 공인 IP 주소를 사용하지 않고도 인터넷 접속 가능
폴리시 NAT: 동적, 정적 NAT 짬뽕. 고정 IP 주소를 가진 장비다? = 정적 NAT를 사용, IP 주소가 동적으로 할당된다? = 동적 NAT 사용.
[해설작성자 : chat gpt]

26. 도메인을 탈취하거나 도메인 네임 시스템 또는 프록시 서버의 주소를 변조함으로써 사용자들로 하여금 진짜 사이트로 오인해 접속하도록 유도한 뒤, 개인 정보를 탈취하는 해킹 기법은?

① 피싱 ② 파밍
③ 스미싱 ④ 봇넷

<문제 해설>
파밍, 피싱(phishing)"과 "농업(farming)"의 합성어
사용자가 자신의 웹 브라우저에서 정확한 웹 페이지 주소를 입력해도 가짜 웹 페이지에 접속하게 하여 개인정보를 훔치는 것
>>> DNS Spoofing이라고 생각하면될듯

피싱(Phising)이 사용자들을 속여 낚는(Fishing)정도라면, 파밍(Pharming)은 도메인 자체를 속이는 차이가 있음ㅁ
[해설작성자 : 정미사랑 나라사랑]

피싱: 이메일, 문자메시지, 웹사이트등을 통해 사용자를 유인해 정보를 수집. ex) 가짜 사이트에 개인정보를 입력
파밍: 사용자가 입력하는 URL을 조작하여 사용자를 유인한다.. 의도되지 않은 사이트로 이동되어 사용자의 개인 정보를 입력하게 하거나 악성 코드들을 설치하게 하게 하는 악성행위이다.
스미싱: 사용자들에게 광고나 스팸 정보를 무단으로 전송하는 행위, 해당 스팸정보에는 악성코드가 들어있을 수 있다.
봇넷: 원격지에서 제어되는 컴퓨터들의 네트워크. 그냥 감염되어 의도치 않은 행위들을 해커에 의해 수행하게 되는 컴퓨터들의 네트워크다..해커가 네크로멘서고, 봇넷들은 좀비라고 생각하면 된다.
[해설작성자 : 누가 더 좋은 설명좀 해줘...]

27. 다음 용어 중 개념상 나머지와 가장 거리가 먼 것은?

① sniffing ② eavesdropping
③ tapping ④ spoofing

<문제 해설>
Sniffing = 패킷들을 훔펴보보기, [Sniff]:"냄새를 맡다.", "킁킁거리다" = 소극적인 공격
eavesdropping = [도청] = 소극적인 공격
tapping = 기계적인 방법을 이용하여 데이터를 도청하는 행위 = 소극적인 공격

spoofing = 변조, 가공해서 탈취공격 등의 시도, 속이다, 사기치다의 뜻 = 적극적 공격
[해설작성자 : 정미사랑 나라사랑]

28. 다음 중 end point에 설치되어 다양한 보안 기능을 통합적으로 수행하는 보안 시스템을 지칭하는 것은?

① IPS ② NAC
③ Firewall ④ UTM

<문제 해설>
NAC 네트워크 접근 제어
네트워크 망 내부에서 서비스 받는 지점의 Host의 보안
[해설작성자 : 정미사랑 나라사랑]

IPS: 네트워크나 시스템에서 일어나는 침입 행위를 실시간으로 감지하고 방지하는 시스템. 네트워크 트래픽을 분석함. 엔드포인트가 아닌 네트워크 단에서 작동
NAC: 네트워크 접근 제어. 네트워크에 접속하려는 클라이언트의 신뢰성, 취약점, 정책 준수 여부를 확인하여 안정적인 네트워크를 유지하는 기술이다..(클라이언트의 신뢰성이니 엔드포인트)
Firewall: 장비 or 소프트웨어이다..네트워크를 보호하기 위해, 외부로부터 입력되는 트래픽을 검사하고 차단한다.(네트워크 쪽에서 발생)
UTM: 장비나 소프트웨어를 통해 보안 위협을 하나의 장비나 소프트웨어에서 관리할 수 있게 하는 기술. AV, 안티 스팸, IDS/IPS, VPN, 필터링, 암호화, 로그 분석 등등 다양한 보안 기능 구현이 가능하다.
[해설작성자 : Chat gpt]

아래와 같은 오류 신고가 있었습니다.
여러분들의 많은 의견 부탁 드립니다.
추후 여러분들의 의견을 반영하여 정답을 수정하도록 하겠습니다.
참고로 정답 변경은 오류 신고 5회 이상일 경우 수정합니다.

[오류 신고 내용]
정답은 4번입니다..NAC는 디바이스의 네트워크 접근 제어에 관여하지 통합 보안 기능을 수행하지 않습니다.
UTM은 end point에 설치되어 방화벽, IPS, 안티바이러스, VPN 등 다중 보안 기능을 통합 제공합니다.

29. 다음 중 전문가 시스템(Expert System)을 이용한 IDS에서 사용되는 침입 탐지기법은?

① Behavior Detection
② State Transition Detection

③ Knowledge Based Detection
④ Statistical Detection

<문제 해설>
IDS(침입탐지시스템)
- 지식 기반 침입탐지: 전문가 시스템, 상태전이, 패턴매칭
- 행동 기반 침입탐지: 통계적분석, 예측 가능한 패턴 생성, 신경망모델
가즈아 21-03-26 20:00 펌
[해설작성자 : 정미사랑 나라사랑]

30. Snort의 각 규칙은 고정된 헤더와 옵션을 가지고 있다. 패킷의 payload 데이터를 검사할 때 사용되는 옵션에 포함되지 않는 필드는?

① ttl ② content
③ depth ④ offset

<문제 해설>
Snort
침입 차단 시스템이자, 네트워크 침입 탐지 시스템, 무료(중요)
약간 패킷단을 들여다 볼때 사용한다 생각

payload 데이터를 검사할때 사용되는 옵션
msg, content, offset, depth, nocase, sid, flow, rev 등
==========
아래는 참고로 읽기만

msg alert 발생 시 이벤트 이름으로 사용됨
reference 룰과 관련된 외부 취약점 정보
sid snort rule id로 사용 범위
classtype 공격유형과 기본 우선순위 정의
priority 룰 우선순위(숫자)
rev rule 버전번호로 수정(revision) 횟수 표기
content 페이로드에서 검사할 문자열을 text 또는 binary 형식으로 지정
[해설작성자 : 정미사랑 나라사랑]

ttl: 살아있는 시간
content: 페이로드의 내용
offset: 패이로드에서 패턴 매칭을 할 시작위치
depth: 페이로드에서 패턴 매칭을 할 끝 위치
[해설작성자 : 쉽게쉽게 설명하자]

31. 이래 지문 빈칸에 들어갈 용어를 바르게 짝지은 것은?

> Tcpdump는 네트워크 인터페이스를 거치는 패킷의 내용을 출력해 주는 프로그램이다. 스니핑 도구의 일종으로 자신의 컴퓨터로 들어오는 모든 패킷의 내용을 모니터링 할 수 있다. LAN 상의 모든 트래픽을 모니터링 하기 위해서는 이더넷 스위치에서의 (가)을 통해 다른 컴퓨터로 향하는 트래픽도 수 신하도록 한다. 이 때 이더넷 모드를 (나)로 변경하여야 컴 퓨터로 들어온 패킷을 운영체제에서 확인할 수 있다.

① 가 : 포트 미러링(Port Mirroring) 나: 수집 모드 (Acquisition Mode)
② 가 : 포트 미러링(Port Mirroring) 나 : 무차별 모드 (Promiscuous Mode)
③ 가 : 패킷 포워딩(Packet Forwarding) 나 : 수집 모드 (Acquisition Mode)
④ 가 : 패킷 포워딩(Packet Forwarding) 나 : 무차별 모드 (Promiscuous Mode)

<문제 해설>
포트 미러링(Port Mirroring)
- 네트워크 스위치에서 스위치 포트를 통과하는 패킷들을 감시 또는 관찰(모니터링)하기 위해
- 패킷들을 다른 스위치 포트로 복사하는 방법

무차별모드(Promiscuous Mode)
- 목적지주소와 장치 주소가 일치하지 않아도 Frame을 버리지 않고 수집하는 모드.
(자신의 MAC주소와 상관없는 패킷이 들어와도 분석할 수 있도록 메모리에 올려 처리)
- 지나가는 모든 트레픽을 감시
[해설작성자 : 한비로 두비로 세비로]

32. 다음 중 VoIP 서비스에 대한 공격과 가장 거리가 먼 것은?

① Register 플러딩 공격
② GET 플러딩 공격
③ INVITE 플러딩 공격
④ RTP 플러딩 공격

<문제 해설>
SIP Flooding 공격 : SIP 메시지를 대량으로 보내기
- Register 플러딩 공격 : 지속적인 Register 요청으로 및 Register 의 시스템 자원 고갈
- INVITE 플러딩 공격 : 수신자의 전화기가 불통이 될 뿐만 아니라 전화벨이 계속 올리는 상황

RTP 플러딩 공격 : 접속 설정 관련 Signal을 이용 두 사용자간 상호 교환한 후 실질적으로 media 전송에 관련 있는 패킷을 이용한 방법
- Cancel 공격 : Cancel 메세지를 보내서 A가 B에게 전화를 걸려 하는데 중간에서 스니핑 한 후 A대신 B에게 취소 통보
- Bye 공격 : INVATE 메세지를 스니핑 하여 BYE 메세지를 생성 후 전화를 하는 중간에 취소 통보
- 스푸핑 공격 : 발신자 변조하여 공격자의 신분을 숨기거나 변조

비정상 메세지 공격
- SIP의 헤더와 바디 내용이 일반 문자로 되어 있다는 점을 이용하여 다른 문자들로 삽입, 변조 혹은 삭제 하는 공격
- 엄청난 수의 공백 문자를 넣어 오버플로우 예외를 발생시킨다거나 특수문자를 넣어 이에 대응하지 못하는 VoIP 서비스의 오작동을 유발
[해설작성자 : 정미사랑 나라사랑]

33. 3개의 IP 패킷으로 fragmentation 되는 과정을 설명한 것이다. 세 번째 패킷의 필드에 들어갈 값으로 적절한 것은?

패킷사이즈	flag	offset
1500	1	0
1500	1	185
(가)	0	(나)

① 가: 1040 , 나: 130 ② 가: 1000 , 나: 370
③ 가: 1040 , 나: 370 ④ 가: 1000 , 나: 125

<문제 해설>
IP Fragmentation(IP 분열)
IP Datagram이 네트워크를 통해 전송될 때, 전송 매체에서 전송될 수 있는 최대 크기인 MTU(Maximum Transmission Unit)보다 클 경우 발생
MTU가 1500 => 20바이트를 뺀 1480이 한번에 보낼 수 있는 양
패킷사이즈 해설
>>입력패킷 : 20(헤더)+3980 (바이트) => 4000
1: 20(헤더) + 1480(payload)
2: 20(헤더) + 1480(payload)
3: 20(헤더) + "1020"(payload)
offset 해설
1480 -> payload를 8바이트로 나눈값, 1480/8 = 185
[해설작성자 : 정미사랑 나라사랑]

위의 분이 잘 설명해주셨느데..좀 더 이해하기 쉽게 적어볼게요.
IP 헤더는 일반적으로 20바이트를 차지합니다.

첫 번째 패킷:

전체 크기: 1500바이트
페이로드: 1500 - 20 = 1480바이트
두 번째 패킷:

전체 크기: 1500바이트
페이로드: 1500 - 20 = 1480바이트
IP fragmentation에서의 offset은 8바이트 단위로 표현됩니다..
따라서 첫 번째 패킷의 페이로드는 1480/8 = 185로, 이는 두 번째 패킷의 offset과 일치합니다.

세 번째 패킷의 offset은 첫 번째와 두 번째 패킷의 페이로드 합계를 8로 나눈 값으로 계산됩니다.
1480 (첫 번째 패킷의 페이로드) + 1480 (두 번째 패킷의 페이로드) = 2960
2960/8 = 370

따라서 세 번째 패킷의 offset은 370입니다.
[해설작성자 : knu]

34. 스위치 장비가 동작하는 방식 중 전체 프레임을 모두 받고 오류 검출 후 전달하는 방식은?

① Cut-through 방식
② Fragment-Free 방식
③ Direct Switching 방식
④ Store and Forward 방식

<문제 해설>
축적 교환(Store-and-Forward) 방식은 일단 들어오는 데이터를 버퍼에 담아두고(Store) CRC 등 에러검출과 같은 처리를 완전히 한이후에 전달(Forward)하는 교환 기법
출처 >> needjarvis.tistory.com/449
[해설작성자 : 정미사랑 나라사랑]

35. VPN의 기능과 가장 거리가 먼 것은?

① 데이터 기밀성 ② 데이터 무결성
③ 접근통제 ④ 시스템 무결성

<문제 해설>
VPN(Virtual Private Network) = 가상의 전용선
* VPN의 장점
데이터 기밀성 : 송수신 되는 데이터의 암호화
데이터 무결성 : 송수신되는 데이터의 내용이 중간에 변경되지 않음을 보장
데이터 인증 : 수신한 데이터가 인증받은 송신자로부터 왔음을 보장
접근통제 : 인증된 사용자에게만 접근 허용

** 시스템 무결성 : 다음과 같은 시스템 파일들 무결성(변경되지 않음)확인 /system ,/usr, /sbin, /bin 등
[해설작성자 : 정미사랑 나라사랑]

36. 스위칭 환경에서의 스니핑 공격 유형 중, 공격자가 “나의 MAC 주소가 라우터의 MAC 주소이다."라는 위조된 ARP Reply를 브로드캐스트로 네트워크에 주기적으로 보내어 스위칭 네트워크상의 다른 모든 호스트들이 공격자 호스트를 라우터로 믿게 하는 공격은?

① Switching Jamming ② ICMP Redirect
③ ARP Redirect ④ DNS Spoofing

<문제 해설>
ARP Redirect 공격
공격자가 호스트들에게 자신이 라우터라고 속여서 호스트들의 패킷이 자신에게 한번 거친 후 라우터로 가도록하는 공격
>> 문제점
공격자가 네트워크에 있는 호스트들이 어떤 패킷을 라우터를 통과해 외부로 보내 통신하려 하는지 감시와 분석가능
[해설작성자 : 정미사랑 나라사랑]

37. 보안 위협과 공격에 대한 설명 중 옳지 않은 것은?

① 분산 반사 서비스 거부 공격(DRDoS : Distributed Reflection DoS)은 DDoS의 발전된 공격 기술로서 공격자의 주소를 위장하는 IP Spoofing 기법과 실제 공격을 수행하는 좀비와 같은 감염된 반사체 시스템을 통한 트래픽 증폭 기법을 이용한다.
② 봇넷을 이용한 공격은 봇에 의해 감염된 다수의 컴퓨터

가 좀비와 같이 C&C 서버를 통해 전송되는 봇 마스터의 명령에 의해 공격이 이루어지므로 공격자 즉 공격의 진원지를 추적하는데 어려움이 있다.

③ Smurf 공격은 ICMP Flooding 기법을 이용한 DoS 공격으로 Broadcast address 주소의 동작특성과 IP Spoofing 기법을 악용하고 있다.

④ XSS(Cross-Site Scripting) 공격은 공격 대상 사용자가 이용하는 컴퓨터 시스템의 브라우저 등에서 악성코드가 수행되도록 조작하여 사용자의 쿠키 정보를 탈취, 세션 하이재킹과 같은 후속 공격을 가능하게 한다.

<문제 해설>
분산 반사 서비스 거부 공격
- DDoS의 발전된 공격 기술
- 공격자의 주소를 위장하는 IP Spoofing 기법이용(송신자 IP 주소를 피해자의 IP로 조작)
- 일반적인 반사서버로 다수의 요청정보를 전송
- 반사(reflection)와 증폭(amplification) 공격으로 나뉨

>> 의도치 않게 공격을 가하게 되는 서버들(감염X)을 반사체(Reflector)라고 함, 겁나 꼬아서 문제내네
[해설작성자 : 정미사랑 나라사랑]

38. 다음 지문의 방법들이 탐지하려는 공격은?

- 비동기화 상태 탐지 - Ack Storm SATI - 패킷의 유실과 재전송 증가 탐지 - 예상치 못한 접속의 리셋

① MITM 공격
② TCP 세션 하이재킹
③ 스푸핑 공격
④ 스머프 공격

<문제 해설>
TCP 세션 하이재킹
- 인증완료된 정상통신 세션을 가로채서 인증 작업 없이 해당 세션으로 통신 하는 행위
>> 사용자인증 무력화

대응방안
- Sniffing, Spoofing공격을 방어하면 상당 부분 방지 가능
- 비동기화 상태 탐지, ACK Storm 탐지, 패킷의 유실과 재전송 증가 탐지, 기대하지 않은 접속의 리셋 확인을 수행
[해설작성자 : 정미사랑 나라사랑]

39. L2 스위치로 구성된 네트워크 환경에서 스니핑 공격에 대한 설명으로 옳지 않은 것은?

① L2 스위치로 구성된 네트워크 환경에서 스니핑 공격을 시도하기 위해 사용되는 주요 방법들로는 ARP Spoofing ICMP Redirect, MAC Address Flooding 등이 있다.

② ARP Spoofing 공격은 공격자가 대상 시스템에 조작된 ARP Request를 지속적으로 전송함으로써 이루어지며, 대상시스템의 ARP cache table을 변조한다.

③ ICMP Redirect 공격은 공격자가 ICMP Redirect 메시지를 생성하여 공격 대상 시스템에게 전송함으로써 공격대상 시스템이 전송하는 패킷이 공격자에게 먼저 전송되도록 한다.

④ MAC Address Flooding 공격은 공격자가 조작된 MAC 주소를 프레임의 출발지 MAC 주소에 설정하여 보내는 과정을 반복함으로써 스위치가 더미허브처럼 동작하도록 한다.

<문제 해설>
ARP Spoofing 공격 기법
기반설명 : 스위치는 모든 트래픽을 MAC 주소를 기반으로 해서 전송
- 공격자는 IP-MAC 주소 매핑을 ARP Request 브로드캐스팅을 통해 알아 낼 수 있음
- ARP 프로토콜은 인증을 요구하는 프로토콜이 아님 >> 그래서
- ARP Reply 패킷을 각 호스트에 보내서 쉽게 ARP Cache를 업데이트시킬 수 있다.(MAC 주소 위조)
- 스니퍼는 Cache가 사라지기 전에 변조된 ARP Reply를 지속적으로 보냄(변조 MAC 유지)
공격에 성공 시 두 호스트는 서로의 MAC 주소를 스니퍼의 MAC 주소로 인식하여
트래픽을 스니퍼에게 전달하게되고 공격자가 패킷 캡처 가능함
[해설작성자 : 한비로]

ARP spoofing -> ARP request를 브로드캐스트로 보내어 MAC 주소를 알아온 뒤 ARP cache table의 내용을 고침. 지속적으로 ARP request를 보내는건 아님
ICMP redirect -> 호스트의 라우팅 테이블을 변조하여 스니핑함
MAC address flooding -> 네트워크 스위치의 MAC 테이블 내용을 강제로 빼내고 유니캐스트 플러딩을 통해 민감한 정보를 의도치 않은 네트워크로 강제 전송하도록 한다.
[해설작성자 : 합격만 시켜주세요..]

40. IDS의 동작 순서를 바르게 나열한 것은?

가. 데이터 가공 및 축약 나. 데이터 수집 다. 분석 및 침입탐지 단계 라. 보고 및 대응(Reporting and Response)

① 가 - 나 - 다 - 라
② 나 - 가 - 다 - 라
③ 나 - 다 - 가 - 라
④ 나 - 다 - 라 - 가

<문제 해설>
1. 데이터 수집 - 전송된 데이터를 [수집]해서 데이터를 얻음
2. 데이터 가공 및 축약 - 데이터를 분석할 수 있도록 [가공], 효율적으로 처리할 수 있게 [축약]하는 과정을 거침
3. 침입분석 및 탐지 단계 - 처리된 데이터를 기존에 정의 된 룰과 [분석]해서 침입인지 아닌지를 [판단]

4. 보고 및 대응 - [침입]으로 판단된 경우 그것을 보고하고 침입에 [대응]하는 조치를 취함
[해설작성자 : 정미사랑 나라사랑]

3과목 : 어플리케이션 보안

41. 다음 중 XML 기반 Web 기술과 관련성이 가장 적은 것은?

① OCSP ② UDDI
③ WSDL ④ SOAP

<문제 해설>
OCSP = 온라인 인증서 상태 프로토콜
X.509를 이용한 전자 서명 인증서의 폐지 상태를 파악하는 데 사용되는 인터넷 프로토콜
[해설작성자 : 닉네임 이 타이밍에 바꾸기]

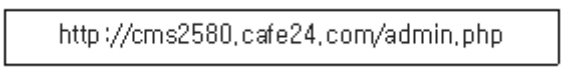
42. 전자입찰시스템 및 프로토콜의 특징에 대한 설명 중 틀린 것은?

① 전자 입찰 도구로는 자바, 디지털서명, XML 등이 이용될 수 있다.
② 입찰 기간 마감은 여러 개의 입찰 서버가 있을 경우 단계적으로 마감된다.
③ 전자 입찰은 입찰자, 입찰 공고자, 전자입찰시스템으로 구성된다.
④ 전자 입찰 시 독립성, 비밀성, 무결성 등이 요구된다.

<문제 해설>
입찰 기간 마감은 여러개 입찰 서버가 있을경우 단계적이 아니라 동시에 마감이되어야합니다.
[해설작성자 : whitebear]

입찰 공고에 명시된 시간에 따라 단일한 마감 시간을 가짐.
여러 개의 입찰 서버가 있더라도 일반적으로 마감 시간은 일괄적으로 적용
[해설작성자 : comcbt.com 이용자]

43. 아래 그림은 공격자가 웹 해킹을 시도하는 화면이다. 아래 화면의 URL을 고려할 때, 공격자가 이용하는 웹 취약점으로 가장 적절한 것은?



① 관리자 페이지 노출 취약점
② 파일 다운로드 취약점
③ 파일 업로드 취약점
④ 디렉터리 리스팅(Directory Listing) 취약점

<문제 해설>
admin.php
누가봐도 admin(관리자) 페이지 일것같은 url주소 확인
[해설작성자 : 정미사랑 나라사랑]

44. 권장하는 함수에 속하는 것은?

① strcat() ② gets()
③ sprintf() ④ strncpy()

<문제 해설>
컴파일 시간 방어 (암기)

프로그램을 컴파일할 때 검사하여 버퍼 오버플로우를 방지하거나 발견하는 것을 목표로 한다.
가장 기본적인 대응책은 버퍼 오버플로우를 허용하지 않는 Java, ADA, Python과 같은 현대화된 고급 프로그래밍 언어를 사용하여 소프트웨어를 작성

사용 자제를 권장하는 함수 : strcat(), strcpy(), get(), scanf(), sscanf(), vscanf(), vsscanf(), sprintf(), vsprintf(), gethostbyname(), realpath()

사용을 권장하는 함수 : strncat(), strncpy(), fgets(), fscanf(), vfscanf(), snprintf(), vsnprintf()
[해설작성자 : 한비로 두비로 세비로]

45. 보안담당자 A씨는 자바스크립트 코드를 분석하기 위해 파일을 열었더니 아래와 같은 내용을 확인할 수 있었다. 아래와 같은 기법의 명칭은? (문제 복원 오류로 그림이 없습니다. 정확한 그림 내용을 아시는분 께서는 오류신고 또는 게시판에 작성 부탁드립니다.)

① 암호화 ② 난독화
③ 복호화 ④ 정규화

<문제 해설>
코드 난독화 = 디컴파일을 하여도 읽기 힘들게 만들기
코드를 읽기 어렵게 만들어 역공학을 통한 공격을 막는 기술
난독화는 난독화의 대상에 따라 크게 두가지로 나눌 수 있다.
1 소스 코드 난독화 : C/C++/자바 등의 프로그램의 소스 코드를 알아보기 힘든 형태로 바꾸는 기술
2 바이너리 난독화 : 컴파일 후에 생성된 바이너리를 역공학을 통해 분석하기 힘들게 변조하는 기술
[해설작성자 : 한비로 두비로 세비로]

46. 다음 지문에서 설명한 프로토콜을 올바르게 나열한 것은?

> 가: 사용자와 은행 사이에서 수행되는 프로토콜로서 은행이 사용자에게 전자 화폐를 발급해 주는 절차를 명세한 프로토콜이다.
> 나: 사용자와 상점 사이에서 수행되는 프로토콜로서 사용자가 구매 대금으로 자신의 전자 화폐를 상점에 지불하는 과정을 명세한 프로토콜이다.
> 다: 상점과 은행 사이에서 수행되는 프로토콜로서 상점이 사용자로부터 받은 전자 화를 은행이 결제해 주는 프로토콜이다.

① 가:인출 프로토콜 나:지불 프로토콜 다:예치 프로토콜
② 가:인출 프로토콜 나:예치 프로토콜 다:지불 프로토콜
③ 가:지불 프로토콜 나:인출 프로토콜 다:예치 프로토콜
④ 가:예치 프로토콜 나:지불 프로토콜 다:인출 프로토콜

<문제 해설>
가 : 은행이 사용자에게 전자화페를 -> 인출
나 : 사용자가 상점에서 전자화페로 -> 지불

다 : 상점이 은행에서 전파화폐를 -> 예치
[해설작성자 : 한비로 두비로 세비로]

인출 프로토콜: 사용자가 자원을 빼내는 데 사용.
지불 프로토콜: 어떤 조건 아래에서 사용자에게 제공하기 위해 자원을 결제
예치 프로토콜: 자원을 미리 제공하고 사용자가 필요할 때 이를 사용할 수 있도록 보증
[해설작성자 : nico1006]

47. 다음의 지문이 설명하는 무선 랜 보안 표준은?

이 무선 랜 보안 표준은 IEEE 802.11(2004년)을 준수하며, 별도의 인증 서버를 이용하는 EAP 인증 프로토콜을 사용하고 암호 키를 동적으로 변경 가능하며, AES 등 강력한 블록 암호 알고리즘을 사용한다.

① WLAN ② WEP
③ WPA ④ WPA2

<문제 해설>
WPA2
- IEEE에서 2004년에 발표한 새로운 암호화 규격,
- WPA2는 AES-CCMP 알고리즘을 사용하는 것이 원칙
- WEP가 너무 짧은 암호화 패킷으로 암호화를 했던것을 강화해서 내놓은 규격(현재 WPA3 발표됨)
[해설작성자 : 한비로 두비로 세비로]

48. 다음 지문이 설명하고 있는 DRM의 구성요소는?

지적재산권으로 보호되어야 할 정보의 단위로 일반적으로 패 키지를 통해 패키징 되기 이전의 원본을 의미한다.

① 콘텐츠 ② 워터마크
③ DOI ④ 컨트롤러

<문제 해설>
콘첸츠 : 보호되어야할 정보 단위, 원본
워터마크 : 디지털 콘텐츠 추적기술, 원저작자 소유권자 입증
DOI : 디지털 콘텐츠 식별기술, 객체 고유 식별자, 콘텐츠에 부여하는 (알파벳+숫자) 기호 체계
컨트롤러 : 배포된 콘텐츠의 이용권한 통제 수단
[해설작성자 : 한비로 두비로 세비로]

49. HTTP의 요청 메소드가 아닌 것은?

① GET ② POST
③ PUSH ④ PUT

<문제 해설>
HTTP 요청 메서드
-GET
-HEAD
-POST
-PUT
-DELETE
-CONNECT
-OPTIONS
-PATCH
[해설작성자 : 한비로 두비로 세비로]

50. 다음 중 디지털 핑거프린팅 기술에 대한 설명으로 옳지 않은 것은?

① 디지털 핑거프린팅 기술은 콘텐츠 내에 소유자 정보와 구매자 정보를 함께 포함하는 핑거프린트 정보를 삽입하여 후에 불법으로 배포된 콘텐츠로부터 배포자가 누구인지를 역추적 할 수 있도록 해 주는 기술이다.
② 핑거프린팅된 콘텐츠는 서로 다른 구매자 정보를 삽입하기 때문에 구매자에 따라 콘텐츠가 조금씩 다르다.
③ 공모공격 (collusion attack)이란 여러 개의 콘텐츠를 서로 비교하여 워터마킹된 정보를 제거하거나 혹은 유추하여 다른 워터마크 정보를 삽입할 수 있는 것을 의미하는데, 이처럼 워터마킹은 공모공격에 취약하지만 디지털 핑거프린팅 기술은 이 공격에 매우 안전하다.
④ 디지털 핑거프린팅 기술은 워터마킹 기술과 같이 삽입과 추출기술로 분류하는데 삽입기술은 삽입하는 정보만 다를뿐 워터마킹 기술과 동일하다.

<문제 해설>
디지털 핑거프린팅
- 삽입된 마크들의 집합
- 사후검출기능 제공으로 불법배포를 보호 : 부정자 추적 기술
- 데이터에 2진 마크를 삽입(워터마크와 비슷)

워터마크와 다른점
- 데이터에 삽입되는 마크의 내용이 모두 다름
- 워터마크는 소유권을 명확히해주나 불법행위자를 알아낼 수는 없음

특징
- 공모위협이 있음(콘텐츠간 상이성을 이용해, 정보지우거나, 새로운 콘텐츠 생성)
- 복제방지기술 X -> 검출과 증명으로 복제 억제 기술 O
[해설작성자 : 한비로 두비로 세비로]

디지털 핑거프린팅: 소유자 및 구매자 정보 삽입, 불법 복제 추적
워터마크: 숨은 정보 삽입, 소유권 주장, 콘텐츠 변조 없음
[해설작성자 : nico1006]

51. DNS Cache를 확인하는 윈도우 명령어는?

```
ds.kisa.or.kr
----------------------------------
데이터 이름.....ds.kisa.or.kr
데이터 유형..... 1
TTL(Time To Live)...7972
데이터 길이..... 5
섹션. ..... 응답
(호스트)레코드..... 121.254.150.6

icms.kisa.or.kr
----------------------------------
데이터 이름.....icms.kisa.or.kr
데이터 유형.. .....1
TTL(Time To Live)...82
데이터 길이..... 5
섹션..... 응답
(호스트)레코드..... 121.254.229.1621
```

① ipconfig/dnsdisplay ② ipconfig/displaydns
③ ipconfig/flushdns ④ ipconig/dnsflush

<문제 해설>
ipconfig/displaydns
: DNS 캐시가 얼마나 쌓여있는지 확인가능

ipconfig/flushdns
: DNS 캐시 삭제(cache를 flush)
[해설작성자 : 한비로 두비로 세비로]

52. 아래는 vsftp의 설정파일인 vsftpd.conf에 대한 설명이다. 올바른 내용을 모두 고르시오.

가: amonymous_enable : 익명 접속 설정으로 권장은 NO이다.
나: port_enable : YES 값은 데이터 전송을 위해서 Passive Mode를 사용하도록 설정한다.
다: xferlog_enable : FTP 로그를 남길 것인지에 대한 설정으로 로그 위치는 vsftpd_log file에서 설정한다.
라: local enable : 로컬 계정 사용자들의 접속 허용을 설정한다.

① 가, 나, 다 ② 가, 다
③ 가, 나, 다, 라 ④ 가, 다, 라

<문제 해설>
port_enable=YES
- 데이터 전송을 위해서 Passive Mode를 사용하지 못하도록 한다
[해설작성자 : 한비로 두비로 세비로]

53. 다음에서 설명하는 정보보호 기술은?

전달하려는 정보를 이미지, 오디오 파일에 인간이 감지할 수 없도록 숨겨 상대방에게 전달하는 기술을 총칭한다.
일반 암호화 방법은 암호화를 통해 정보의 내용을 보호하는 기술인 반면에 이 기술은 정보의 존재 자체를 숨기는 보안 기술이다.

① 핑거프린트(Fingerprint)
② DOI(Digital Object Identifier)
③ 디지털 워터마크(Digital watermark)
④ 스테가노그래피(Steganography)

<문제 해설>
스테가노그래피
- 스테가노(στεγᾰνός)는 "덮어지거나 감추어진" + "통신하다"는 그래피(γραφή)를 결합
전달하려는 기밀 정보를 파일, 메시지, 이미지 또는 비디오를 파일, 메시지, 이미지, 비디오 안에 숨기는 심층 암호 기술
[해설작성자 : 한비로 두비로 세비로]

54. 다음 지문은 무엇을 설명한 것인가?

- TCP/IP 프로토콜에서 전송 계층 바로 위에 위치하며 보안기능을 수행한다.
- 사용자 상호인증, 데이터 기밀성, 메시지 무결성 등의 보안서비스를 제공한다.
- Handshake 프로토콜, Change Cipher Spec, Aler 프로토콜 Record 프로토콜로 구성된다.

① IPSec ② PGP
③ SSL/TLS ④ SHTTP

<문제 해설>
Transport Layer Security (=전송 계층 보안)
- 전송계층 바로 위에서 보안기능 수행

TCP 계층 위 SSL의 프로토콜
- Change Cipher Spec Protocal : 암호화 알고리즘과 보안 정책
- Alert Protocal : 2바이트로 구성된 오류 메세지를 담는 프로토콜
- Handshake Protocal : 암호 알고리즘 결정, 키 분배, 서버 및 클라이언트 인증 수행
[해설작성자 : 한비로]

55. 다음 지문이 설명하는 전자 거래 문서의 유형으로 알맞은 것은?

데이터의 저장 및 교환을 위한 대표적 문서교환 표준인 SGM (Standard Generalized Markup Language)과 HIM (Hyper Tel Merkup Largage)의 장점을 모두 가지고 있다.
1996년 W3C에서 제안하였으며, 웹상에서 구조화된 문서를 전송 가능하도 록 설계된 웹표준이며, 최근 전자거래 및 각종 업무에서 표준으로 폭넓게 채택되어 사용되고 있다.

① SWIFT
② ebXML
③ EDI(Electronic Data Interchange)
④ XML(Extensible Markup Language)

<문제 해설>
ebXML (electronic business XML)
ebXML은 "비즈니스" 데이터를 안전하게 주고받는데 XML을 사용하는 개방형 표준을 가리킨다.
1999년에 UN/CEFACT와 OASIS가 합동 발기하여 시작, ebXML은 XML 기반의 메시지 교환을 통해 전세계 전자상거래 시장에서 안전한 비즈니스 거래가 이루어질 수 있도록 설계되었다..ebXML 프로젝트는 1999년에 UN/CEFACT와 OASIS가 합동하여 시작되었으며, 회원사는 전 세계의 주요 IT 공급사와 무역 관련업체를 포함하여 모두 75개사에 달한다..ebXML은 HTTP, TCP/IP, MIME, SMTP, FTP, UML, 및 XML 등과 같은 기존의 인터넷 표준에 기반을 두고 있기 때문에, 실제로 어떠한 종류의 컴퓨터 플랫폼에서도 구현될 수 있다..기존의 표준을 사용함으로써 사용하기 쉽고 비용도 비교적 적게 든다는 장점이 있다.

EDI(Electronic Data Interchange)
기업 간 거래에 관한 데이터와 문서를 표준화하여 컴퓨터 통신망으로 거래 당사자가 직접 송수신하는 정보 전달 시스템이다..주문서납품서청구서 등 무역에 필요한 각종 서류를 표준화된 상거래 서식 또는 공공 서식을 통해 서로 합의된 전자신호로 바꾸어 컴퓨터 통신망을 이용해 거래처에 전송한다..전자문서교환에서 사용하는 국제적인 통신 표준은 현재 국제연합이 중심이 되어 만든 UN/EDIFACT의 표준을 따르고 있다

XML(Extensible Markup Language)
XML은 데이터의 저장 및 교환을 위한 대표적 문서 교환 표준인 SGML(Standard Generalized Markup Language)과 HTML(Hyper Text Markup Language)의 장점을 모두 가질 수 있도록 1996년 W3C(World Wide Web Consortium)에서 제안했으며, 웹상에서 구조화된 문서를 전송 가능하도록 설계된 정보 교환을 위한 웹 표준이다..최근 전자거래 및 각종 업무에서 표준으로 채택되어 사용되고 있다.
[해설작성자 : 한비로 두비로 세비로]

56. 다음 보기가 설명하는 취약성은?

이것은 암호화를 위해 대중적으로 사용되는 OpenSSL 라이브 러리에서 서버 메모리 중 64KB의 데이터에 대해 공격자가 덤프를 뜰 수 있게 하는 취약점이다. 해당 취약점을 이용하여 시스템 메모리에 저장되어 있는 무의미한 작은 정보들을 지속적으로 유출시키면, 이러한 무의미한 정보들이 모여 하나의 완전한 유의미한 정보가 될 수 있다. 특히 개인키의 경우 암 호화하여 전달되는 데이터를 모두 열람할 수 있는 핵심정보 이기때문에 매우 심각한 취약성이라 할 수 있다.

① Poodle ② Ghost
③ Shellshock ④ Heartbleed

<문제 해설>
하트블리드
[>>피가 한 방울씩 떨어지는 치명적인 심장출혈(HeartBleed)에 비유]
- 응용 프로그램 메모리의 최대 64 킬로바이트를 들추어내는데 이용
- 소프트웨어가 허용된 것보다 더 많은 데이터를 읽게 하는 상황
- 무의미한 정보들이 모여 하나의 완전한 유의미한 정보를 만듦
[해설작성자 : 한비로]

57. 다음 표는 Apache 웹 서버의 주요 파일에 대한 접근권한을 나타낸다. 각각에 들어갈 내용으로 적절한 것은?

디렉터리	소유자	그룹	권한
bin	root	root	755
httpd	root	root	(가)
passwd	root	(나)	640
httpd.conf	root	nobody	(다)
log	root	root	755

① 가:640 나:root 다:511
② 가:511 나:nobody 다:640
③ 가:640 나:nobody 다:511
④ 가:511 나:root 다:640

<문제 해설>
(가)httpd는 프로그램으로 소유자가 실행할 수 있어야 하므로 x 권한이 있어야합니다 따라서 소유자는 r-x -> 5로 시작
(나)passwd는 루트권한만 실행가능 해야하므로 nobody
(다)httpd.conf는 환경설정 파일로 실행권한이 없어도 됩니다 따라서 소유자는 rw- -> 6으로 시작
[해설작성자 : sieger]

58. SSL/TLS에 대한 설명으로 옳은 것은?

① 상위계층 프로토콜의 메시지에 대해 기밀성과 부인방지를 제공한다.
② 종단 대 종단 간의 안전한 서비스를 제공하기 위해 UDP를 사용하도록 설계하였다.
③ 레코드(Record) 프로토콜에서는 응용계층의 메시지에 대해 단편화, 압축, MAC 첨부, 암호화 등을 수행한다.
④ 암호명세 변경(Change Cipher Spec) 프로토콜에서는 클

라이언트와 서버가 사용할 알고리즘과 키를 협상한다.
<문제 해설>
SSL Record Protocol은 데이터 교환에 사용되는 것으로 메시지 분할,압축,무결성,인증,암호화를 제공한다.
[해설작성자 : 시험준비중...]

여지없이 3번 정답 맞습니다..TLS 1.3에서는 압축 단계가 제거되었으나, 문제에서는 레코드 프로토콜의 전반적인 기능을 묻고 있으므로 3번이 가장 적절합니다.
[해설작성자 : comcbt.com 이용자]

59. 다음 중 PGP의 기능이 아닌 것은?
① 기밀성
② 전자서명
③ 단편화와 재조립
④ 송수신 부인방지
<문제 해설>
기능
- 기밀성
-전자서명(무결성, 사용자 인증, 송신자 부인 봉쇄)
: 수신 부인방지 기능 없음
-압축(ZIP)
-전자우편 호환성
[해설작성자 : 한비로 두비로 세비로]

60. 다음 중 데이터베이스 보안 유형이 아닌 것은?
① 접근 제어(Access Control)
② 허가 규칙(Authorization Rule)
③ 암호화(Encryption)
④ 집합(Aggregation)
<문제 해설>
데이터베이스 보안 설계
접근제어 : 허가받지 않은 접근 통제
허가규칙 : 로그인, 접근통제를 거쳐 들어온 사람의 권한을 가진 데이터만 접근
암호화 : 데이터에 접근하더라도 데이터를 암호화 하는것
가상테이블 : 노출하고 싶은 필요한 정보들만
[해설작성자 : 한비로 두비로 세비로]

4과목 : 정보 보안 일반

61. 국내 암호모듈 검증에 있어 검증대상 암호알고리즘으로 지정된 비밀키 블록암호 알고리즘으로 구성된 것은?
① 가:AES, 나:LEA 다:SEED
② 가:AES, 나:LEA 다:ARIA
③ 가:ARIA, 나:LEA 다:SEED
④ 가:ARIA, 나:AES 다:SEED
<문제 해설>
(가)
- 2004년 국가보안기술연구소(NSRI)주도로 학계, 연구소, 정부기관의 지원을 받아 개발
- 경량 환경 및 하드웨어 구현을 위해 최적화된 Involitional SPN 구조를 가진 범용 블록암호
- 국내기관에서 주도적 개발, 국내 국가표준으로 지정
- 전자정부 구현에 사용 SPN 구조를 가짐

(나)
- 2012년 국가보안기술연구소가 개발한 128bit 경량 고속 블록암호 알고리즘
- 다양한 정보보호 서비스에서 대용량 데이터를 빠르게 처리하거나 스마트폰, IoT 저전력 암호화에 사용가능

(다)
- 1999년 한국인터넷진흥원과 국내 암호전문가들이 함께 개발
- 인터넷, 전자상거래, 무선통신등에서 사용하기 위해 만든 대칭 알고리즘
- 128bit 비밀키에서 생성된 16개의 64비트 라운드키를 사용하여 128비트 평문 블록을 128비트의 암호문 블록으로 암호화
- Feistel 구조를 가짐

AES
- 1997년 미국 NIST에서 DES를 대체할 새로운 암호알고리즘 공모
- 2000년 새로운 미국표준 블록암호로 채택됨
- 대칭형, 블럭 암호화 알고리즘
- AES는 하드웨어와 소프트웨어로 구현하기 쉽다
[해설작성자 : 한비로]

62. 사용자 인증에서는 3가지 유형의 인증방식을 사용하고 있으며, 보안을 강화하기 위하여 2가지 유형을 결합하여 2 factor 인증을 수행한다. 다음 중 2 factor 인증으로 적절하지 않은 것은?
① USB 토큰, 비밀번호
② 스마트카드, PIN(Personal Identification Number)
③ 지문, 비밀번호
④ 음성인식, 수기서명
<문제 해설>
[Factor의 구분]
지식기반
- 패스워드, PIN코드, 설정해놓은 질문답변
소유기반
- 휴대폰 인증, 보안카드, OTP 등
- 공인인증서, 스마트폰, 스마트카드, USB 토큰 등
생체 기반
- 지문인식, 홍채인식, 정맥인식, 얼굴인식 등
[해설작성자 : 한비로 두비로 세비로]

63. 강제적 접근통제 정책에 대한 설명으로 옳지 않은 것은?
① 모든 주체와 객체에 보안관리자가 부여한 보안레이블이 부여되며 주체가 객체를 접근할 때 주체와 객체의 보안레이블을 비교하여 접근허가 여부를 결정한다.
② 미리 정의된 보안규칙들에 의해 접근허가 여부가 판단되므로 임의적 접근통제 정책에 비해 객체에 대한 중앙 집중적인 접근통제가 가능하다.

③ 강제적 접근통제 정책을 지원하는 대표적 접근통제 모델로는 BLP(Bell-Lapadula), Biba 등이 있다.
④ 강제적 접근통제 정책에 구현하는 대표적 보안 메커니즘으로 Capability List와 ACL(Access Control List) 등이 있다

<문제 해설>
강제적 접근통제 정책(= MAC)
주체, 객체 등급 기간 접근 권한 정책, 중앙집중적, 경직적

>> Capability List(기능목록)와 ACL(접근 통제 목록)는 임의적 접근통제 정책 (= DAC)
[해설작성자 : 한비로 두비로 세비로]

64. 다음 지문이 설명하고 있는 프로토콜은?

- 공유할 암호키를 계산하여 만들어낸다. - 유한체상의 이산대수문제를 풀기 어려움에 기반한다. - 중간자 공격이나 재전송 공격에는 취약하다.

① Needham-Schroeder 프로토콜
② 공개키 암호
③ KDC 기반 키 분배
④ Diffie-Hellman 프로토콜

<문제 해설>
이산대수를 사용하는 공개키 프로토콜은 디프헬만이다.
[해설작성자 : Melbourne]

65. 아래 보기에서 설명하고 있는 공격기법은?

1997년 Diffie와 Hellman이 제안하였으며 암호화할 때 일어날 수 있는 모든 가능한 경우에 대하여 조사하는 방법으로 경우 의 수가 적을 때는 가장 정확한 방법이지만, 일반적으로 경우의 수가 많은 경우에는 실현 불가능하다.

① 차분 공격(Differential Cryptanalysis)
② 선형 공격(Linear Cryptanalysis)
③ 전수 공격(Exhaustive key search)
④ 통계적 분석(Statistical analysis)

<문제 해설>
67번 문제와 해설 동일
차분공격(Differential Cryptanalysis)
- Buham과 Shamir 개발
- CPA(선택 평문공격)의 종류로 비트의 [차이]를 이용하여 암호키를 찾아내는 방법

선형공격(Linear Cryptanalysis)
- Matsui 개발
- KPA(기지 평문 공격)의 종류로 [비선형 구조를 선형화] 시켜 암호키를 찾아내는 방법

전수공격(Exhaustive key search)
- Diffe와 Hellman 이 제안
- 가능한 [모든 경우에 대하여 조사]하는 방법

통계적 분석 (Statistical analysis)
- [통계적인 자료]를 이용하여 해독하는 방법
[해설작성자 : 한비로 두비로 세비로]

66. 소프트웨어로 구성되는 난수 생성기를 가장 적절하게 표현한 것은?

① SRNG ② HRNG
③ PRNG ④ RRNG

<문제 해설>
PRNG(Psudeo Random Number Generator) : 의사(가짜) 난수 생성기
- 난수를 생성하는 소프트웨어
- 소프트웨어만으로는 진정한 난수를 생성할 수가 없기 때문에, 의사 난수 생성기라 부른다

HRNG(Hardware Random Number Generator) : 하드웨어 난수 발생기
- 난수를 생성하는 하드웨어 장치
- 특정 물리적현상을 전기적신호로 변환하고 반복하여 일련의 무작위 난수값을 얻는다.
(알고리즘을 이용하는게 아닌 물리적 처리를 통해얻음)
[해설작성자 : 한비로]

67. 아래 보기에서 설명하고 있는 공격기법은?

1990년 Bham과 Sharir에 의하여 개발된 선택 평문 공격법 으로, 두 개의 평문 블록의 비트 차이에 대하여 대응되는 암호문 블록들의 비트 차이를 이용하여 사용된 암호키를 찾아 내는 방법이다.

① 차분 공격(Differential Cryptanalysis)
② 선형 공격(Linear Cryptanalysis)
③ 전수 공격(Exhaustive key search)
④ 통계적 분석(Statistical analysis)

<문제 해설>
차분공격(Differential Cryptanalysis)
- Buham과 Shamir 개발
- CPA(선택 평문공격)의 종류로 비트의 [차이]를 이용하여 암호키를 찾아내는 방법

선형공격(Linear Cryptanalysis)
- Matsui 개발
- KPA(기지 평문 공격)의 종류로 [비선형 구조를 선형화] 시켜 암호키를 찾아내는 방법

전수공격(Exhaustive key search)
- Diffe와 Hellman 이 제안
- 가능한 [모든 경우에 대하여 조사]하는 방법

통계적 분석 (Statistical analysis)

- [통계적인 자료]를 이용하여 해독하는 방법
[해설작성자 : 한비로]

68. 다음의 장·단점을 가진 인증기술은?

- 장점 : 데이터의 기밀성, 무결성 보장 - 단점 : 키 분배센터(인증서버 & 티켓발급서버)에 오류 발생시 전체 서비스 이용불가

① 커버로스(Kerberos) 프로토콜
② OTP 인증
③ ID/패스워드 인증
④ 메시지 출처 인증

<문제 해설>
커버로스 프로토콜 -> 75번 문제와 해설 동일
"티켓"(ticket)을 기반으로 동작
보안이 보장되지 않은 네트워크 환경에서 요청을 보내는 유저와 요청을 받는 서버가 서로의 신뢰성을 확보하기위해 사용된다

단점
다운되면 기존에 이미 로그인된 유저를 제외한 새롭게 로그인을 시도하는 유저가 서버에 접속하는것이 불가능해진다.
[해설작성자 : 한비로 두비로 세비로]

69. 키 관리는 키 생성, 분배, 설치, 갱신, 취소 폐기, 저장, 복구 등을 요구하는 포괄적인 개념이다. 한 사용자 또는 기관이 비밀키를 설정하여 다른 사용자에게 전달하는 기술을 키 분배라고 하며, 둘 또는 그 이상의 사용자가 공개된 통신 채널을 통하여 비밀키를 설정하는 것을 키 합의라고 한다. 다음 중 키 분배 방식에 해당되는 것은?

① Diffie-Hellman 방식
② Matsumoto-Takashima-Imai 방식
③ Okamoto-Nakamura 방식
④ Needham-Schroeder 방식

<문제 해설>
Diffie-Hellman 키 교환 방식
키 분배 센터(KDC, Key Distribution Center)없이 대칭키를 생성할 수 있는 암호 프로토콜
공유 방식으로 세션키를 분배
중간자 공격에 취약(도청 및 조작)

MTI (Matsumoto-Takashima-Imai) 키 공유 방식
Diffie-Hellman Key Exchange를 수정하여 문제 개선한 프로토콜을 구성함
A와 B가 항상 동일한 세션키를 가지는 문제 개선
설정은 Diffie-Hellman 키 사전 배포와 동일

Okamoto-Nakamura 키 공유 방식
키 공유 방식
사용자가 암호 통신 때마다 다른 세션키 사용 가능.

Needham-Schroeder 키 분배 방식
대칭키와 trent 개념을 사용
재전송 공격 취약점 가짐
[해설작성자 : 한비로]

70. 다음 중 해시함수의 특징이 아닌 것은?

① 고정된 크기의 해시코드를 생성함
② 일방향성(one-wayness)
③ 강 · 약 충돌 회피성이 보장됨
④ 안전한 키를 사용할 경우 결과값의 안전성이 보장됨

<문제 해설>
해시함수란
임의의 길이를 갖는 메시지를 입력받아 고정된 길이의 해시값을 출력하는 함수
암호 알고리즘에는 키가 사용되지만, 해시 함수는 키를 사용하지 않으므로 같은 입력에 대해서는 항상 같은 출력이 나옴
이러한 해시함수를 사용하는 목적은 메시지의 오류나 변조를 탐지할 수 있는 무결성을 제공하기 위해 사용

해시 함수의 특징
- 어떤 입력 값에도 항상 고정된 길이의 해시값을 출력한다.
  > 고정길이 : 어떠한 값을 주더라도 짧은 고정길이 해시값을 생성해야함
- 눈사태 효과 : 입력 값의 아주 일부만 변경되어도 전혀 다른 결과 값을 출력한다.
  > 충돌저항성 : 입력 값은 항상 동일한 해시 값을 출력한다.(무결성 보장)
- 출력된 결과 값을 토대로 입력값을 유추할 수 없다.
  > 일방향성 : 해시값으로 역산 할 수 없어야함
[해설작성자 : 정미]

71. 다음 중 암호시스템에 대한 수동적 공격은?

① 트래픽 분석
② 메시지 순서 변경
③ 메시지 위조
④ 삭제 공격

<문제 해설>
소극적 공격
- 시스템으로부터 정보를 획득하거나 사용하려는 시도
- 시스템 자원에는 영향을 끼치지 않는 공격
- 탐지가 힘듦
종류 : 스니핑, 트래픽 분석 (기밀성 침해)

적극적 공격
- 시스템 자원을 변경하거나 시스템 작동에 영향을 끼치는 공격
- 탐지가 쉬움
종류 : 변조, 가장, 재전송, 부인 (무결성 침해), DOS (가용성 침해)
[해설작성자 : 정미사랑 나라사랑]

72. 다음 중 스트림 암호의 특징으로 알맞지 않은 것은?

① 원타임 패스워드를 실용적으로 구현할 목적으로 개발되었다.
② 짧은 주기와 높은 선형복잡도가 요구되며 주로 LFSR을

이용한다.
③ 블록단위 암호화 대비 비트단위로 암호화하여 암호화 시간이 더 빠르다.
④ 블록 암호의 CFB, OFB 모드는 스트림 암호와 비슷한 역할을 한다.

<문제 해설>
스트림 암호(Stream Cipher)
- 블록 암호에 비해 경량 및 고속 동작이 용이 : 무선환경, 스트리밍에서 이용
- 암호화의 연속은 긴 주기를 가져야 한다.
- 스트림 암호는 블록 단위가 아닌 비트 단위로 암호화
- 전사적 공격에 대응하기 위해, 키가 충분히 길어야 한다.
- A5/1, A5/2 등의 알고리즘이 존재
예시 : OTP, LFSR, MUX generator
[해설작성자 : 한비로 두비로 세비로]

73. "한 단계 앞의 암호문 블록"을 대신할 비트열을 무엇이라 하는가?
① 패딩 ② 초기화 벡터
③ 스트림 블록 ④ 운영모드

<문제 해설>
초기화 벡터(initialization vector)
- 최초의 평문 블록을 암호화할 때 1단계 앞의 암호문 블록이 존재하지 않으 므로 1단계 앞의 암호문 블록을 대신할 비트열 블록이 준비되어야 한다..

패딩
- 실제 CBC 모드를 적용할 경우에 암호화될 평문의 길이는 가변적이기 때문에 마지막 블록이 블록의 길이와 항상 딱 맞아떨어지지 않게 된다..부족한 길이만큼을 '0' 으로 채우거나 임의의 비트들로 채워 넣는 것을 패딩이라고 한다.
[해설작성자 : 한비로 두비로 세비로]

74. 이중서명(Dual Signature)은 사용자가 구매정보와 지불정보를 각각 해시한 후 해시값을 합하여 다시해시 그리고 최종 해시값을 카드 사용자의 개인키로 암호화한 서명을 말하는 것으로 이중서명 절차이다. 이중서명을 사용하는 것으로 적합한 것은?
① SET ② PKI
③ 전자화폐 ④ 전자수표

<문제 해설>
걍 외우기 공식임
이중서명 + 신용카드 = SET
[해설작성자 : 한비로 두비로 세비로]

75. 다음 지문이 설명하는 것은?

> 이것은 MIT(Massachusetts Institute of Technology) 대학에서 개발한 분산 환경 하에서 개체 인증서비스를 제공하는 네트워크 인증시스템이다. 비밀키 암호작성법에 기초를 둔 자주 이용되는 온라인 암호키 분배 방법이다. 이 시스템의 목적은 인증된 클라이언트만이 서버에 접속하도록 하는 것이다. 이것의 장점으로는 데이터의 기밀성과 무결성을 보장한다는 점을 들 수 있고, 이것의 단점으로는 키 분배센터에 장애 발생 시 전체서비스가 사용 불가 상태가 됨을 들 수 있다.

① Diffie-Hellman Protocol
② Kerberos Protocol
③ Needham-schroeder Protocol
④ SET Protocol

<문제 해설>
커버로스 프로토콜
"티켓"(ticket)을 기반으로 동작
보안이 보장되지 않은 네트워크 환경에서 요청을 보내는 유저와 요청을 받는 서버가 서로의 신뢰성을 확보하기위해 사용된다

단점
다운되면 기존에 이미 로그인된 유저를 제외한 새롭게 로그인을 시도하는 유저가 서버에 접속하는것이 불가능해진다.
[해설작성자 : 한비로 두비로 세비로]

76. 다음 중 임의적 접근통제(DAC : Dscretionary access control) 에 해당하는 특징이 아닌 것은?
① 사용자 기반 및 ID 기반 접근통제
② 중앙 집중적 관리가 가능
③ 모든 개개의 주체와 객체 단위로 접근권한 설정
④ 객체의 소유주가 주체와 객체 간의 접근통제 관계를 정의

<문제 해설>
1) 강제적 접근 통제 (MAC, Mandatory Access Control)
주체와 객체의 보안 등급을 비교하여 접근 권한을 부여하는 접근통제
장점
- 모든 객체에 관리가 용이
- 중앙 집중식 관리이기 때문에 매우 엄격한 보안 제공
단점
- 매우 제한적인 사용자 기능과 많은 관리적 부담을 요구하며 비용이 많이 소모
- 모든 접근에 대해 확인해야 하므로 성능이 저하

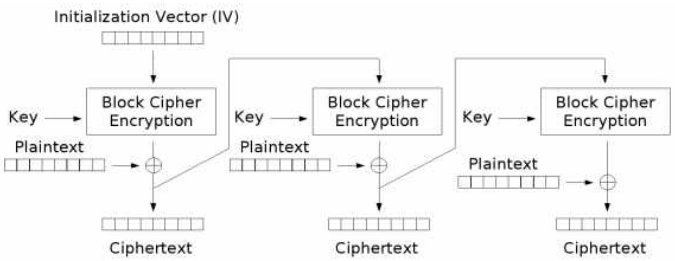
2) 임의적 접근 통제 (DAC, Discretionary Access Control)
신원에 근거하여 객체에 대한 접근을 제한하는 방법
장점
-객체별로 세분화된 접근제어가 가능
- 특정 주체가 다른 주체에 대해 임의적으로 접근제어가 가능
- 매우 유연한 접근 제어 서비스를 제공
단점

- 시스템 전체 차원의 일관성 있는 접근제어가 부족
[해설작성자 : 한비로 두비로 세비로]

77. 다음 중 대칭 암호 알고리즘이 아닌 것은?
① BlowFish ② SEED
③ Diffie-Hellman ④ 3DES
<문제 해설>
BlowFish - DES, IDEA를 대신하여 사용되는 키(key) 방식의 대칭형 블록 암호
SEED - 대칭키 블록 암호 알고리즘
Diffie-Hellman - 공개 키 암호 방식
3DES - 대칭형 블록 암호 알고리즘
[해설작성자 : 한비로 두비로 세비로]

78. 다음 중 인증서가 폐지되는 사유가 아닌 것은?
① 인증서 발행 조직에서 탈퇴
② 개인키의 손상
③ 개인키의 유출 의심
④ 인증서의 유효기간 만료
<문제 해설>
제18조(공인인증서의 폐지)
1. 가입자 또는 그 대리인이 공인인증서의 폐지를 신청한 경우
2. 가입자가 사위 기타 부정한 방법으로 공인인증서를 발급받은 사실을 인지한 경우
3. 가입자의 사망·실종선고 또는 해산 사실을 인지한 경우
4. 가입자의 전자서명생성정보가 분실·훼손 또는 도난·유출된 사실을 인지한 경우
[해설작성자 : 한비로 두비로 세비로]

79. 다음 그림은 블록암호 운용모드의 한 종류를 나타낸 것이다. 다음 그림에 해당하는 블록암호 운용모드는?



① CBC(Cipher Block Chaining)
② ECB(Electronic CodeBook)
③ CTR(CounTeR)
④ CFB(Cipher FeedBack)
<문제 해설>
▶ Cipher FeedBack 모드(암호 피드백 모드)
CBC의 변형으로, 블록 암호를 비트 스트림으로 생각하는 방식.

그림순서와 특징(내맘대로 설명)
1. 그림 맨위에 초기벡터(IV) 필요
2. 초기벡터를 바로 암호화(Encryption)
3. 평문블록(Plaintext)과 XOR(⊕) 하여서
3. 암호문 블록(Ciphertext)를 만든다
스트림 데이터 암호화나 인증에 자주 사용됨.
평문과 암호문의 길이가 같음
[해설작성자 : 한비로]

80. n명의 사람이 대칭키 암호화 통신을 할 경우 몇 개의 대칭키가 필요한가?
① n(n+1)/2 ② n(n-1)/2
③ n(n-1) ④ n(n+1)
<문제 해설>
대칭키 알고리즘
장점 : 상대적으로 단순
단점 : 키관리에 어려움

> 두 사용자마다 하나의 키를 공유해야하기때문에 n명이 가입한 경우 n(n-1)/2 개 필요
> 각 사용자는 n-1개의 키를 관리해야함
[해설작성자 : 한비로 두비로 세비로]

5과목 : 정보보안 관리 및 법규

81. 괄호에 공통적으로 들어갈 적정한 것은?

( )은 정보시스템 또는 정보보호시스템의 결함 또는 손실에 의하여 발생되고, 정보보호 대책을 적용함으로써 감소시킬 수 있다. 그러나( )이 없는 시스템은 존재하지 않고, 주기적인 진단과 패치의 적용에도 불구하고, 새로운 ( )이 발생되기 때문에 완전제거는 불가능하다

① 취약점 ② 위협
③ 위험 ④ 침해
<문제 해설>
1. 위험(risk)
- 예상되는 위협에 의한 자산에 발생할 가능성이 있는 손실의 기대치
- 취약점 악용 위협으로 인한 자산 손실, 손상 또는 파괴 가능성
- 위협요소가 일으킬 수 있는 피해
- 관리가 가능하다.

2. 위협(threat)
- 손실이나 손상의 원인이 될 가능성의 제공하는 환경
- 보안에 해를 끼치는 행동이나 사건
- 위험을 일으킬 소지가 다분한 요소

3. 취약점(vulnerability)
- 위협에 의하여 손실이 발생하게 되는 자산의 약점
- 기능 명세, 설계 또는 구현 단계의 오류나 시동, 설치 또는 운용상의 문제점으로 인하여 정보 시스템이 지니게 되는 보안 취약점
- 실제 공격 구현이 가능한 오류

출처 : t-okk.tistory.com/87
[해설작성자 : 정미사랑 나라사랑]

82. 위험분석 방법론으로 적절히 짝지은 것은?

가: 그 어떤 사건도 기대대로 발생하지 않는다는 사실에 근거하여 일정 조건 하에서 위협에 대한 발생 가능한 결과를 추정하는 방법 나: 시스템에 관한 전문적인 지식을 가진 전문가 집단을 구성하고 위협을 분석 및 평가하며 정보시스템이 직면한 다양 한 위협과 취약성을 토론을 통해 분석하는 방법

① 가: 확률분포법 나: 순위결정법
② 가: 시나리오법 나: 델파이법
③ 가: 델파이법 나: 확률분포법
④ 가: 순위결정법 나:시나리오법

<문제 해설>
시나리오법 : 기대대로 발생되지 않는다 치고, 발생가능한것 순위를 매기기
델파이 : 전문가집단에게 의견요청, 정확도는 낮음
[해설작성자 : 한비로 두비로 세비로]

83. 「개인정보보호법」에 의거하여 개인정보처리자는 개인정보의 처리에 대하여 정보주체의 동의를 받을 때에는 각각의 동의 사항을 구분하여 정보주체가 이를 명확하게 인지할 수 있도록 알리고 각각 동의를 받아야 한다. 동의를 서면으로 받을 때에는 중요한 내용을 정하는 방법에 따라 명확히 표시하여 알아보기 쉽게 하도록 되어 있다. 이때 중요한 내용에 해당되지 않는 것은?

① 동의를 거부할 권리가 있다는 사실 및 거부에 따른 불이익이이 있을 경우에는 불이익에 대한 내용
② 개인정보를 제공받는 자
③ 개인정보를 제공받는 자의 개인정보 이용 목적
④ 개인정보의 보유 및 이용 기간

<문제 해설>
22조에 (생략) 동의를 서면으로 받을 때는 중요한 내용을 정하는 방법에 따라 (생략) 하도록
되어 있다..라고 되어 있습니다.
중요한 내용은 개인정보보호법 시행령 제 17조에 명시가 되어 있는데
이 문제 1번 항목은 표시가 되어 있지 않네요
[해설작성자 : 그림자의 주인]

제22조(동의를 받는 방법)에 따른 시행령 제17조를 보면 다음과 같음
1. 개인정보의 수집·이용 목적 중 재화나 서비스의 홍보 또는 판매 권유 등을 위하여 해당 개인정보를 이용하여 정보주체에게 연락할 수 있다는 사실
2. 처리하려는 개인정보의 항목 중 다음 각 목의 사항
가. 민감정보
나. 제19조제2호부터 제4호까지의 규정에 따른 여권번호, 운전면허의 면허번호 및 외국인등록번호
3. 개인정보의 보유 및 이용 기간(제공 시에는 제공받는 자의 보유 및 이용 기간을 말한다)
4. 개인정보를 제공받는 자 및 개인정보를 제공받는 자의 개인정보 이용 목적
[해설작성자 : 김나박이]

84. 「개인정보보호법」에 의거하여 공공기관의 장은 대통령령으로 정하는 기준에 해당하는 개인정보 파일의 운용으로 인하여 정보주체의 개인정보 침해가 우려되는 경우에는 그 위험 요인의 분석과 개선사항 도출을 위한 영향평가를 하고 그 결과를 행정안전부장관에게 제출하여야 한다. 영향평가를 하는 경우에 고려해야 할 사항으로 적합하지 않은 것은?

① 처리하는 개인정보의 수
② 개인정보의 제3자의 제공 여부
③ 정보주체의 권리를 해할 가능성 및 그 위험 정도
④ 개인정보를 처리하는 수탁업체 관리·감독의 여부

<문제 해설>
제33조(개인정보 영향평가)
② 영향평가를 하는 경우에는 다음 각 호의 사항을 고려하여야 한다.
1. 처리하는 개인정보의 수
2. 개인정보의 제3자 제공 여부
3. 정보주체의 권리를 해할 가능성 및 그 위험 정도
4. 그 밖에 대통령령으로 정한 사항
[해설작성자 : 한비로 두비로 세비로]

85. "개인정보 보호법"에서 개인정보의 파기 및 보존 시 가장 적절하지 않은 경우는?

① 개인정보의 이용목적이 달성된 때에는 즉시 파기하여야 한다.
② 개인정보 삭제 시 만일의 경우에 대비하여 일정기간 보관한다.
③ 개인정보를 파기하지 않고 보관할 시에는 다른 개인정보와 분리하여 저장 · 관리한다.
④ 전자적 파일 형태인 경우, 복원이 불가능한 방법으로 영구 삭제한다.

<문제 해설>
제2조 (개인정보의 처리 및 보유 기간)
이용자 개인정보는 원칙적으로 개인정보의 처리목적이 달성되면 지체없이 파기합니다.
[해설작성자 : 한비로 두비로 세비로]

86. 「개인정보보호법」에 의거하여 개인정보처리자가 정보주체 이외로부터 수집한 개인정보를 처리하는 때에는 정보주체의 요구가 있으면 즉시 정보주체에게 알려야 하는 사항들에 해당되지 않는 것은?

① 개인정보 처리의 정지를 요구할 권리가 있다는 사실
② 개인정보의 보유·이용 기간
③ 개인정보의 수집 출처
④ 개인정보의 처리 목적

<문제 해설>
제20조(정보주체 이외로부터 수집한 개인정보의 수집 출처 등

통지
개인정보처리자가 정보주체 이외로부터 수집한 개인정보를 처리하는 때에는 정보주체의 요구가 있으면 즉시 다음 각 호의 모든 사항을 정보주체에게 알려야 한다.
1. 개인정보의 수집 출처
2. 개인정보의 처리 목적
3. 제37조에 따른 개인정보 처리의 정지를 요구하거나 동의를 철회할 권리가 있다는 사실
[해설작성자 : 김나박이]

87. 다음 지문이 설명하는 위험분석방법론은?

- 시스템에 관한 전문적인 지식을 가진 전문가의 집단을 구성하고 위험을 분석 및 평가하여 정보시스템이 직면한 다양한 위협과 취약성을 토론을 통해 분석하는 방법이다. - 위험 분석을 짧은 기간에 도출할 수 있어 시간과 비용을 절약할 수 있지만, 추정의 정확도가 낮다.

① 과거자료 분석법
② 확률 분포법
③ 델파이법
④ 시나리오법

<문제 해설>
Delphi(=그리스 아폴로의 신전이름)법
- 신전에 엎드려 일어날 일을 예측요청한다고해서 이름붙여짐(이러면 외우기편함)
- 전문가들의 견해를 유도하고 종합하여 집단적 판단으로 정리하는 일련의 절차
- 관리자(의견조정자)가 주관이 돼 전문가 5~20명의 의견을 2~3회 청취하고 피드백을 받아 최종 라운드 예측의 평균값 또는 중앙값으로 결과를 예측하는 방법
[해설작성자 : 한비로]

88. 정보보호 사전점검에 대한 설명으로 옳은 것은?

① 정보보호 사전점검은 전자적 침해행위에 대비하기 위한 정보시스템의 취약점 분석 평가와 이에 기초한 보호대책의 제시 또는 정보보호 관리체계 구축 등을 주된 목적으로 한다.
② 방송통신위원회는 사업자가 사전점검을 실시하거나 실시 계약을 체결한 경우 해당 사업 또는 서비스에 대하여 가점을 부여하는 등 우대조치를 할 수 있다.
③ 사전점검 수행기관으로 지정받으려는 자는 수행기관 지정 신청서를 방송통신위원회에 제출하여야 한다.
④ 사전점검 대상 범위는 제공하려는 사업 또는 정보통신서비스를 구성하는 하드웨어, 소프트웨어, 네트워크 등의 유무형 설비 및 시설을 대상으로 한다.

<문제 해설>
1. 정보보호 사전점검은 전자적 침해행위에 대비하기 위한 정보시스템의 취약점 분석 평가와 이에 기초한 보호대책의 제시 또는 정보보호 관리체계 구축 등을 주된 목적으로 한다..>>정보보호컨설팅에 대한 정의

2. 방송통신위원회는 사업자가 사전점검을 실시하거나 실시 계약을 체결한 경우 해당 사업 또는 서비스에 대하여 가점을 부여하는 등 우대조치를 할 수 있다..>> 사전점검 실시 우대에 대한 정의

3. 사전점검 수행기관으로 지정받으려는 자는 수행기관 지정 신청서를 방송통신위원회에 제출하여야 한다..>> 사전점검 수행기관 지정 신청

4. 사전점검 대상 범위는 제공하려는 사업 또는 정보통신 서비스를 구성하는 하드웨어, 소프트웨어, 네트워크 등의 유무형 설비 및 시설을 대상으로 한다..>> 사전점검 대상 범위
[해설작성자 : 한비로 두비로 세비로]

89. 도출된 위험이 해당 사업에 심각한 영향을 주는 관계로 보험에 가입하였다. 이런 식으로 위험을 경감 또는 완화시키는 처리 유형은 무엇인가?

① 위험 감소(reduction)
② 위험 전가(transfer)
③ 위험 수용(acceptance)
④ 위험 회피(avoidance)

<문제 해설>
위험 감소
위험 감소란 위험을 감소시킬 수 있는 대책을 채택하여 구현하는 것
비용이 소요되기 때문에 실제 감소되는 위험의 크기를 비교하는 비용 효과 분석을 실시

위험 전가
위험 전가란 보험이나 외주 등으로 잠재적 비용을 제3자에게 이전하거나 할당하는 것

위험 수용
위험 수용이란 현재의 위험을 받아들이고 잠재적 손실 비용을 감수하는 것
일정 수준 이하의 위험은 어쩔 수 없는 것으로 인정

위험 회피
위험 회피는 위험이 존재하는 프로세스나 사업을 수행하지 않고 포기하는 것
[해설작성자 : 한비로 두비로 세비로]

90. 다음 중 공인인증기관이 발급하는 공인인증서에 포함되어야 하는 사항이 아닌 것은 무엇인가?

① 가입자의 전자서명검증정보
② 공인인증서 비밀번호
③ 가입자와 공인인증기관이 이용하는 전자서명방식
④ 공인인증기관의 명칭 등 공인인증기관을 확인할 수 있는 정보

<문제 해설>
제15조(공인인증서의 발급)

② 공인인증기관이 발급하는 공인인증서에는 다음 각호의 사항이 포함되어야 한다. <개정 2001. 12. 31.>
1. 가입자의 이름(법인의 경우에는 명칭을 말한다)
2. 가입자의 전자서명검증정보
3. 가입자와 공인인증기관이 이용하는 전자서명 방식
4. 공인인증서의 일련번호
5. 공인인증서의 유효기간
6. 공인인증기관의 명칭 등 공인인증기관임을 확인할 수 있는 정보
7. 공인인증서의 이용범위 또는 용도를 제한하는 경우 이에 관한 사항
8. 가입자가 제3자를 위한 대리권 등을 갖는 경우 또는 직업상 자격등의 표시를 요청한 경우 이에 관한 사항
9. 공인인증서임을 나타내는 표시
[해설작성자 : 한비로 두비로 세비로]

91. 고유식별정보는 법령에 따라 개인을 고유하게 구별하기 위하여 부여된 식별정보로서 대통령령으로 정하는 정보이다. 다음 중 개인정보처리자가 고유식별정보를 처리할 수 있는 경우에 해당하는 것은?

① 정보주체의 동의를 받지 않은 경우
② 법령에서 구체적으로 고유식별정보의 처리를 요구하거나 허용하는 경우
③ 교통단속을 위하여 필요한 경우
④ 시설 안전 및 화재 예방을 위하여 필요한 경우

<문제 해설>
고유식별정보의 처리 제한 요약
- 개인정보 수집·이용의 경우 정보주체에게 다음의 사항을 알리고 다른 개인정보의 처리에 대한 동의와 별도의 동의를 얻은 경우
- 개인정보 제공의 경우 정보주체에게 사항을 알리고 다른 개인정보의 처리에 대한 동의와 별도의 동의를 얻은 경우
- 법령에서 구체적으로 고유식별정보의 처리를 요구하거나 허용하는 경우

다음의 어느 하나에 해당하는 경우를 제외하고는 주민등록번호를 처리할 수 없음
1. 법률·대통령령·국회규칙·대법원규칙·헌법재판소규칙·중앙선거관리위원회규칙 및 감사원규칙에서 구체적으로 주민등록번호의 처리를 요구하거나 허용한 경우
2. 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 명백히 필요하다고 인정되는 경우
3. 위의 경우에 준하여 주민등록번호 처리가 불가피한 경우
[해설작성자 : 한비로 두비로 세비로]

92. 다음 중 이래 지문의 빈칸 안에 들어가야 할 단어 또는 문장으로 가장 적합한 것은?

> 개인정보 보호법」 제2조(정의) 이 법에서 사용하는 용어의 뜻 은 다음과 같다.
> "개인정보'란 살아 있는 개인에 관한 정보로서 성명 (가) 및 영상 등을 통하여 개인을 알아볼 수 있는 정보 (해당 정보만으로는 특정 개인을 알아볼 수 없더라도 다른 정보 와 쉽게 (하여 알아볼 수 있는 것을 포함한다)를 말한다.
> 「정보통신망법」 제2조정의) 1이 법에서 사용하는 용어의 뜻 은 다음과 같다. "개인정보란 생존하는 개인에 관한 정보로서 성명 (가) 등에 의하여 특정한 개인을 알아볼 수 있는 부호 · 문자· 음성 · 음향 및 영상 등의 정보(해당 정보만으로는 특 정 개인을 알아볼 수 없어도 다른 정보와 쉽게 (나)하여 알아 볼 수 있는 경우에는 그 정보를 포함한다)를 말한다.

① 가:주민등록번호 나: 구분
② 가:성별 나: 유추
③ 가:주민등록번호 나: 결합
④ 가:성별 나: 구분

<문제 해설>
(가) "개인정보"란 살아 있는 개인에 관한 정보로서 다음 각 목의 어느 하나에 해당하는 정보를 말한다.
가. 성명, "[주민등록번호]" 및 영상 등을 통하여 개인을 알아볼 수 있는 정보

제2조(정의)
6. "개인정보"란 생존하는 개인에 관한 정보로서 성명·주민등록번호 등에 의하여 특정한 개인을 알아볼 수 있는 부호·문자·음성·음향 및 영상 등의 정보(해당 정보만으로는 특정 개인을 알아볼 수 없어도 다른 정보와 쉽게 "[결합]"하여 알아볼 수 있는 경우에는 그 정보를 포함한다)를 말한다. - 삭제됨 <2020. 2. 4.>
[해설작성자 : 한비로 두비로 세비로]

93. 개인정보영향평가 시 반드시 고려할 사항이 아닌 것은?

① 처리하는 개인정보의 수
② 개인정보 취급자의 인가 여부
③ 개인정보의 제3자 제공 여부
④ 정보주체의 권리를 해할 가능성 및 그 위협

<문제 해설>
개인정보 보호법 시행령 제36조(영향평가 시 고려사항)
- 처리하는 개인정보의 수
- 개인정보의 제3자 제공 여부
- 정보주체의 권리를 해할 가능성 및 그 위험 정도
- 민감정보 또는 고유식별정보의 처리 여부
- 개인정보 보유기간
[해설작성자 : 정미사랑 나라사랑]

94. 개인정보의 안정성 확보조치 기준(고시)의 제7조(개인정보의 암호화)에 따라 반드시 암호화하여 저장해야하는 개인정보가 아닌 것은?

① 비밀번호 ② 고유식별번호
③ 바이오 정보 ④ 전화번호

<문제 해설>
개인정보의 안정성 확보조치 기준(고시)의 제7조
① [고유식별정보], [비밀번호], [바이오정보정보]를 통신망을 통하여 송신하거나 보조저장매체 등을 통하여 전달하는 경우에는 이를 암호화하여야 한다..
[해설작성자 : 한비로]

95. 다음은 정보통신기반 보호법에 따른 주요 정보통신기반시설의 지정요건이다. 빈칸 가 ~ 마 에 들어갈 알맞은 단어를 바르게 나열한 것은?

중앙행정기관의 장은 소관분야의 정보통신기반시설중 다음의 사항을 고려하여 전자적 침해행위로부터의 보호가 필요하다고 인정되는 정보통신기반시설을 주요정보통신기반시설로 지정할 수 있다. 1. 당해 정보통신기반시설을 관리하는 기관이 수행하는 업무의 국가 사회적 (가) 2. 당해 정보통신기반시설을 관리하는 기관이 수행하는 업무의 정보통신기반시설에 대한 (나) 3. 다른 정보통신기반시설과의 (다) 4. 침해사고가 발생할 경우 국가안전보장과 경제사회에 미치는 피해규모 및 범위 5. 침해사고의 (라) 또는 그 복구의 (마)

① 가:중요성 나:기밀성 다:의존도 라:발생가능성 마:용이성
② 가:기밀성 나:중요성 다:의존도 라:용이성 마:경제성
③ 가:중요성 나:의존도 다:상호연계성 라:발생가능성 마:용이성
④ 가:의존도 나:중요성 다:상호연계성 라:발생가능성 마:용이성

<문제 해설>
지정 기준
중앙행정기관의 장은 소관분야의 정보통신기반시설중 다음 각호의 사항을 고려하여 전자적 침해행위로부터의 보호가 필요하다고 인정되는 정보통신기반시설을 주요정보통신기반시설로 지정할 수 있다.
- 당해 정보통신기반시설을 관리하는 기관이 수행하는 업무의 국가사회적 [중요성]
- 제1호의 규정에 의한 기관이 수행하는 업무의 정보통신기반시설에 대한 [의존도]
- 다른 정보통신기반시설과의 [상호연계성]
- 침해사고가 발생할 경우 국가안전보장과 경제사회에 미치는 피해규모 및 범위
- 침해사고의 [발생가능성] 또는 그 복구의 [용이성]
[해설작성자 : 한비로 두비로 세비로]

96. 「개인정보보호법」상에서 민감정보로 명시되어 있는 것은?

① 혈액형 ② 사상·신념
③ 결혼 여부 ④ 성별

<문제 해설>
민감정보란
① 사상•신념,
② 노동조합•정당의 가입•탈퇴,
③ 정치적 견해,
④ 건강, 성생활 등에 관한 정보,
⑤ 그 밖에 정보주체의 사생활을 현저히 침해할 우려가 있는 개인정보
로서 대통령령이 정하는 정보를 의미
[해설작성자 : 한비로 두비로 세비로]

97. 다음 정보보호 관리체계 인증제도에 대한 설명으로 가장 적절하지 않은 것은?

① 정보통신서비스와 직접적인 관련성이 낮은 전사적 자원관 리시스템(ERP), 분석용 데이터베이스(DW), 그룹웨어 등 기업 내부 시스템, 영업/마케팅 조직은 일반적으로 인증 범위에서 제외해도 된다.
② 인증범위는 신청기관이 제공하는 정보통신서비스를 기준으로 해당 서비스에 포함되거나 관련 있는 자산(시스템, 설비, 시설 등), 조직 등을 포함하여야 한다.
③ ISMS 의무인증범위 내에 있는 서비스, 자산, 조직(인력)을 보호하기 위한 보안시스템은 포함 대상에서 제외해도 된다.
④ 해당 서비스의 직접적인 운영 및 관리를 위한 백오피스 시스템은 인증범위에 포함되며, 해당 서비스와 관련이 없더라도 그 서비스의 핵심정보자산에 접근 가능하다면 포함하여야 한다.

<문제 해설>
ISMS 의무 인증 범위 기준
- 정보통신서비스란 인터넷 등 전기통신사업자의 전기통신역무를 이용하여 정보를 제공하거나 정보의 제공을 매개하는 서비스를 말함
- 인증범위는 신청기관이 제공하는 정보통신서비스를 기준으로, 해당 서비스에 포함되거나 관련 있는 자산(시스템, 설비, 시설 등), 조직 등을 모두 포함
- 해당 서비스의 직접적인 운영 및 관리를 위한 백오피스 시스템은 인증범위에 포함되며,
해당 서비스와 관련이 없더라도 그 서비스의 핵심정보자산에 접근가능 하다면 포함
- ISMS 의무인증범위 내에 있는 서비스, 자산, 조직(인력)을 보호하기 위한 보안시스템은 모두 포함
- 정보통신서비스와 직접적인 관련성이 낮은 전사적자원관리시스템(ERP), 분석용데이터 베이스(DW), 그룹웨어 등 기업 내부 시스템, 영업/마케팅 조직은 일반적으로 인증범위에서 제외
[해설작성자 : 한비로]

98. 다음 지문이 설명하는 인증제도는?

현재 사용되는 IT 보안제품에 대해 보안성을 평가하는 제도로 제품유형별 PP(Prolection Profile)를 정의하고, 8개 군의 평가항 목을 대상으로 평가가 이루어진다. 평가결과는 IT 보안제품의 보안위협 및 자산가치의 정도에 따라 EAL1(Evaluation Assurance Level 1) - EAL7(Evaluation Assurance Level 7) 까지 7단계로 부여하며 인증서가 제공된다.

① ISO 27001 ② ITSEC
③ CC(Common Criteria) ④ ISMS

<문제 해설>
ISO 27001 : 정보보호경영시스템
- 정보보호 관리를 위한 표준화 된 실무 규약

ITSEC : 시스템에 대한 평가 기준
- 영국, 프랑스, 독일, 네델란드 주축으로 고유의 보안성 평가 기준서 개발
-기밀성, 무결성, 가용성을 다룬다.

CC (Common Criteria) : 공통평가기준, 컴퓨터 보안을 위한 국제 표준
- IT 제품이나 특정 사이트의 정보 시스템에 대해 정보 보안평가 인증을 위한 평가 기준이다.
[해설작성자 : 한비로 두비로 세비로]

99. 다음의 지문이 설명하는 정보보호 용어는?

이것은 각종 재해나 재난의 발생을 대비하기 위하여 핵심 시스템의 가용성과 신뢰성을 회복하고 사업의 지속성을 유지하기 위한 일련의 계획과 절차를 말한다. 이것은 단순한 데이터의 복구나 신뢰도를 유지하는 것 뿐 아니라 나아가 기업의 전체적인 신뢰성 유지와 가치를 최대화하는 방법과 절차이다.

① 재난 예방 계획
② 업무연속성 계획
③ 기업 안정성 확보 계획
④ 시스템 운영 계획

<문제 해설>
업무 연속성 계획(BCP)이란
사이버 공격, 자연 재해 또는 기타 외부 요인으로 업무가 중단될 경우를 예방하고 복구할 수 있는 시스템을 의미하는 절차

장점
- 브랜드 평판 유지
- 고객과 직원 신뢰 구축
- 업무 운영 유지관리
- 경쟁 우위 확보
- 재무 위험 완화
[해설작성자 : 한비로 두비로 세비로]

100. 개인정보처리자는 다음 지문의 사항이 포함된 것을 정하고 이를 정보주체가 쉽게 확인할 수 있게 공개하도록 되어 있다. 다음 지문의 사항이 포함된 문서의 법률적 명칭은 무엇인가?

1. 개인정보의 처리 목적
2. 개인정보의 리 및 보유 기간
3. 개인정보의 제3자의 제공에 관한 사항(해당도는 경우에만 정한다.)
4. 개인정보처리의 위탁에 관한 사항해당도는 경우에만 정한다.)
5. 정보주체의 권리의무 및 그 행사방법에 관한 사항
6. 그 밖에 개인정보의 처리에 관하여 대통령령으로 정한 사항

① 개인정보 보호정책
② 표준 개인정보 보호지침
③ 개인정보 보호지침
④ 개인정보 처리방침

<문제 해설>
한국인터넷진흥원(KISA)의 개인정보 처리방침(2022-01-21 기준)
- 제1조 개인정보의 처리 목적
- 제2조 개인정보의 처리 및 보유기간
- 제3조 개인정보의 제3자 제공에 관한 사항
- 제4조 개인정보 처리의 위탁
- 제5조 정보주체와 법정대리인의 권리·의무 및 행사방법
- 제6조 처리하는 개인정보 항목
- 제7조 개인정보의 파기 절차 및 방법
- 제8조 개인정보의 자동수집 장치의 설치·운영 및 거부에 관한 사항
- 제9조 개인정보 안전성 확보 조치
- 제10조 권익침해 구제방법
- 제11조 개인정보의 열람청구

네이버의 개인정보 처리방침
1. 처리하는 개인정보 항목
2. 개인정보의 처리목적
3. 개인정보의 제3자 제공
4. 개인정보 처리의 위탁
5. 개인정보의 처리 및 보유기간
6. 개인정보 파기절차 및 방법
7. 정보주체의 권리·의무 및 그 행사방법
8. 개인정보의 안전성 확보조치
9. 개인정보 자동 수집 장치의 설치·운영 및 거부에 관한 사항
10. 개인정보보호 책임자 및 연락처
11. 기타
12. 개인정보처리방침의 변경
[해설작성자 : 한비로 두비로 세비로]

본 해설집의 저작권은 www.comcbt.com에 있으며
카페, 블로그 등의 업로드 및 개인적 활용 이외에
문서의 수정 및 DB 저장, 기타 금전적 이익을 취하는 일체의 행위를 금지 합니다.

전자문제집 CBT 홈페이지 : www.comcbt.com
기출문제 및 해설집 다운로드 : www.comcbt.com/xe
전자문제집 CBT 앱(구글플레이) : [다운로드]

전자문제집 CBT란? 인터넷으로 종이 없이 문제를 풀고 자동채점하는 프로그램으로 워드, 컴활, 기능사 등의 상설검정에서 사용하는 실제 프로그램 방식입니다.
해설을 제공하며 PC 버전 및 모바일 버전 완벽 연동
교사용/학생용 관리기능도 제공합니다.

오답 및 오탈자가 수정된 최신 자료와 해설은 전자문제집 CBT에서 확인하세요.

1	2	3	4	5	6	7	8	9	10
②	②	④	①	③	①	④	③	③	①
11	12	13	14	15	16	17	18	19	20
③	③	④	③	③	②	④	④	④	④
21	22	23	24	25	26	27	28	29	30
③	③	④	②	④	②	④	②	③	①
31	32	33	34	35	36	37	38	39	40
②	②	③	④	④	③	①	②	②	②
41	42	43	44	45	46	47	48	49	50
①	②	①	④	②	①	④	①	③	③
51	52	53	54	55	56	57	58	59	60
②	④	④	③	④	④	②	③	④	④
61	62	63	64	65	66	67	68	69	70
③	④	④	④	③	③	①	①	④	④
71	72	73	74	75	76	77	78	79	80
①	②	②	①	②	②	③	④	④	②
81	82	83	84	85	86	87	88	89	90
①	②	①	④	②	②	③	④	②	②
91	92	93	94	95	96	97	98	99	100
②	③	②	④	③	②	③	③	②	④